



AL-ITTIHAD MULTINATIONAL ORGANIZATION

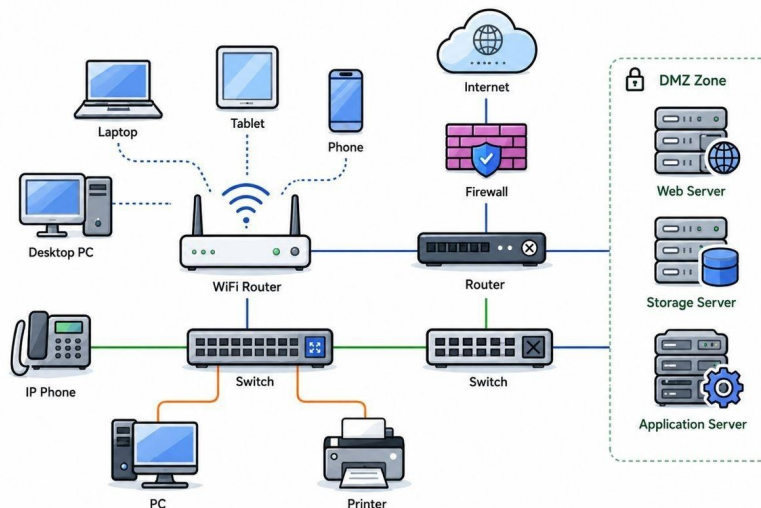
CYBER RISK ASSESSMENT INITIATIVE

CONFIDENTIAL – Restricted Access

CYBER RISK ASSESSMENT REPORT

Information Security Risk Management Engagement

Conducted in accordance with ISO/IEC 27005 & ISO/IEC 27002



AL-ITTihad Network Architecture (In-Scope Environment)

CONFIDENTIAL — Restricted to Authorized Recipients

Field	Detail
Report Reference	ALI-CRA-2026-01
Version	1.0
Reporting Period	Q2 2026
Date of Issue	03 June 2026
Prepared by	Internal Cyber Audit Team, AL-ITTihad Multinational Organization
Prepared for	Executive Management & the IT Security Steering Committee



Document Control

This report is a controlled document. Its distribution is restricted to the recipients listed below, and any reproduction or onward circulation requires the authorization of the Chief Information Security Officer.

Document Identification

Field	Detail
Title	Cyber Risk Assessment Report
Reference	ALI-CRA-2026-01
Version	1.0
Status	Final — for Management Review
Classification	CONFIDENTIAL
Prepared by	Internal Cyber Audit Team
Reviewed by	Lead Cyber Risk Auditor
Approved by	Chief Information Security Officer (CISO)
Distribution	Executive Management; CISO; IT Security Steering Committee; IT Department Heads

Internal Cyber Audit Team

The engagement was performed by AL-ITTIHAD's Internal Cyber Audit Team. Each auditor was assigned a defined role to ensure clear ownership and segregation of responsibilities across the assessment lifecycle.

Auditor	Engagement Role
Anas Faozi Abdullah Al-Abi	Lead Cyber Risk Auditor — engagement ownership, methodology, sign-off
Ibrahim Khaled Abdullah Omar	Security Analyst — asset inventory, threat & vulnerability identification
Khaled Gamil Alhasani	Risk Analyst — risk scenario development, scoring, risk register
Salman Dahir Abdullahi	Controls & Compliance Auditor — control mapping, treatment & ISO alignment

Version History

Version	Date	Description	Author
1.0	03 Jun 2026	Initial issue — Context Establishment and Risk Identification baseline	Internal Cyber Audit Team

Table of Contents

Document Control.....	2
Document Identification.....	2
Internal Cyber Audit Team.....	2
Version History.....	2
Section A: Context Establishment.....	8
A.1 Engagement Background & Organizational Profile.....	8
A.2 Audit Objectives.....	9
A.3 Scope of Assessment.....	10
A.3.1 Network Segments in Scope.....	10
A.3.2 Exclusions (Out of Scope).....	11
A.4 Operating Environment.....	11
A.4.1 Regulatory & Compliance Environment.....	12
A.5 Stakeholders.....	12
A.6 Business Objectives — The CIA Triad.....	13
A.7 Risk Assessment Criteria.....	14
A.7.1 Likelihood Scale.....	15
A.7.2 Impact Scale.....	15
A.7.3 Risk Level Definition (Risk Rating Classification).....	16
A.8 Risk Acceptance Criteria.....	16
A.9 Assumptions & Constraints.....	17
A.10 Reference Standards & Frameworks.....	18
A.11 Asset Inventory & Valuation.....	19
A.11.1 Category 1 — Hardware Assets.....	19
A.11.2 Category 2 — Software Assets.....	21

A.11.3 Category 3 — Data Assets.....	22
A.11.4 Category 4 — Network Assets.....	24
A.11.5 Category 5 — Service Assets.....	25
A.11.6 Detailed Asset Specifications.....	26
A.11.7 Asset Ownership Matrix.....	28
A.12 Asset Valuation & Criticality Methodology.....	30
A.12.1 Asset Inventory Summary.....	30
Section B: Risk Identification.....	31
B.1 Risk Identification Methodology.....	32
B.2 Asset Identification (Risk-Relevant Subset).....	32
B.3 Threat Source Identification.....	33
B.3.1 Threat Event Catalogue.....	33
B.3.2 Detailed Threat Profiles.....	34
B.4 Vulnerability Identification.....	35
B.4.1 Vulnerability Profiles.....	36
B.5 Existing Control Inventory.....	37
B.5.1 Attack Surface Summary.....	38
B.6 Risk Scenario Development.....	41
RS-01: Web Server DDoS (Availability).....	41
RS-02: Phishing Credential Theft (Confidentiality).....	42
RS-03: Ransomware on Storage Server (Availability / Integrity).....	42
RS-04: SQL Injection on Application Server (Confidentiality / Integrity).....	43
RS-05: Wireless Man-in-the-Middle (Confidentiality).....	44
RS-06: Malware Propagation on Internal LAN (Integrity / Availability).....	45
RS-07: VPN Credential Theft (Confidentiality).....	46

RS-08: Firewall Zero-Day Exploit (Confidentiality / Availability).....	46
RS-09: Insider Interception of VoIP (Confidentiality).....	47
RS-10: Router Brute-Force Compromise (Confidentiality / Availability).....	48
RS-11: Social Engineering of Staff (Confidentiality).....	49
RS-12: Printer Document Interception (Confidentiality).....	49
B.7 Risk Identification Summary.....	50
B.8 CIA Impact Mapping.....	51
Section C: Risk Analysis.....	52
C.1 Analysis Method.....	52
C.2 Detailed Risk Analysis (RS-01 to RS-12).....	52
RS-01 — Web Server (DMZ) / DDoS Attack.....	52
RS-02 — Employee Endpoints / Phishing / Spear-Phishing.....	53
RS-03 — Storage Server (DMZ) / Ransomware.....	54
RS-04 — Application Server (DMZ) / SQL Injection.....	54
RS-05 — Wi-Fi Router / Clients / Man-in-the-Middle.....	55
RS-06 — Internal Switches / LAN / Malware / Trojan.....	56
RS-07 — VPN / Remote Access / VPN Credential Theft.....	56
RS-08 — Firewall (FortiGate 100F) / Zero-Day Exploit.....	57
RS-09 — IP Phone / Telephony / Insider Threat.....	58
RS-10 — Router (Cisco ISR 4321) / Brute Force / Password Attack.....	58
RS-11 — Employee Endpoints / Mobile / Social Engineering.....	59
RS-12 — Printer (HP LaserJet) / Man-in-the-Middle.....	60
C.3 Consolidated Risk Analysis Results.....	61
C.4 Risk Matrix (5 × 5 Likelihood × Impact).....	62
C.5 Key Observations.....	62

C.6 Risk Driver Classification.....	63
C.7 Assumptions & Confidence.....	64
C.8 Consolidated Risk Register.....	65
Section D: Risk Evaluation.....	67
D.1 Risk Evaluation Introduction.....	67
D.2 Risk Evaluation Criteria.....	68
D.3 Complete Risk Evaluation Table.....	69
D.4 Risk Prioritization.....	71
D.5 Top Five Risks.....	73
1. RS-07 — VPN / Remote Access (VPN Credential Theft).....	73
2. RS-02 — Employee Endpoints (Phishing / Spear-Phishing).....	73
3. RS-01 — Web Server (DMZ) (DDoS Attack).....	74
4. RS-03 — Storage Server (DMZ) (Ransomware).....	74
5. RS-04 — Application Server (DMZ) (SQL Injection).....	74
D.6 Risk Matrix.....	75
D.7 Risk Evaluation Summary.....	75
Section E: Risk Treatment.....	77
E.1 Risk Treatment Introduction.....	77
E.2 Risk Treatment Approaches.....	78
E.3 Risk Treatment Decision Criteria.....	79
E.4 Risk Treatment Plan.....	80
E.5 Residual Risk Assessment.....	83
E.6 Treatment Prioritization.....	85
E.7 Risk Treatment Summary.....	86
Section F: ISO/IEC 27002 Control Mapping.....	87

F.1 Introduction.....	87
F.2 ISO/IEC 27002 Overview.....	88
F.3 Control Selection Methodology.....	89
F.4 Risk-to-Control Mapping Table.....	90
F.5 Control Justification.....	92
F.5.1 Access Control.....	92
F.5.2 Network Security.....	92
F.5.3 Backup Management.....	93
F.5.4 Logging and Monitoring.....	93
F.5.5 Security Awareness.....	93
F.5.6 Vulnerability Management.....	94
F.5.7 Incident Management.....	94
F.5.8 Secure Configuration.....	94
F.6 Control Effectiveness Discussion.....	94
F.6.1 Control Implementation Roadmap.....	96
F.7 Section Summary.....	98
Section G: Risk Acceptance.....	99
G.1 Introduction.....	99
G.2 Residual Risk Assessment.....	100
G.3 Risk Acceptance Criteria.....	101
G.4 Accepted Risk Register.....	102
G.5 Cost-Benefit Analysis.....	104
G.6 Business Justification.....	104
G.7 Operational Constraints.....	105
G.8 Residual Risk Monitoring Plan.....	106



G.9 Continuous Review and Improvement.....	107
G.10 Final Conclusion.....	108

Section A: Context Establishment

The Context Establishment phase forms the foundation of this engagement and corresponds to Phase 1 of the ISO/IEC 27005 risk management process. Its purpose is to define the boundaries within which all subsequent activities — risk identification, analysis, evaluation and treatment — are performed, so that the results of the assessment are relevant, consistent and defensible. This section establishes the engagement scope, the operating environment, the stakeholders, the organization's business objectives, the risk assessment and acceptance criteria against which every risk is measured, the assumptions and constraints governing the work, the reference standards applied, and a comprehensive inventory and valuation of the information assets in scope.

A.1 Engagement Background & Organizational Profile

AL-ITTIHAD is a multi-jurisdictional, multinational organization operating across several countries. Its business activities are supported by a complex information technology infrastructure that includes cloud-based systems, a range of end-user devices, a segregated demilitarized zone (DMZ) hosting public-facing services, and Virtual Private Network (VPN)-enabled remote access for employees working from home (WFH). Because AL-ITTIHAD operates across multiple legal jurisdictions, its information processing is simultaneously subject to several data-protection regimes, which materially raises both its regulatory exposure and the complexity of its threat landscape.

In recognition of the rising frequency and sophistication of cyber-attacks targeting multinational enterprises, AL-ITTIHAD has established an Internal Cyber Audit Team and mandated it to design and execute a structured Cyber Risk Management Plan aligned to ISO/IEC 27005 (information security risk management) and ISO/IEC 27002 (information security controls). This report is the primary deliverable of that mandate. It documents the context, identifies and analyses the organization's principal cyber risks, and provides management with the prioritized, evidence-based basis required to make risk treatment and acceptance decisions.

AL-ITTIHAD's reliance on technology spans customer-facing services delivered from the DMZ, internal business applications, and a distributed workforce that connects remotely over VPN. This operating model delivers reach and flexibility but also widens the organization's attack surface: public-facing servers are continuously exposed to the Internet, remote access extends the trust boundary beyond the office perimeter, and a multinational footprint multiplies the regulatory regimes that apply to the same data. The engagement was scoped with these characteristics in mind so that the assessment reflects the organization's real-world exposure rather than an idealized network.

A.2 Audit Objectives

The engagement was conducted to achieve the following three objectives, which map directly to the early phases of the ISO/IEC 27005 lifecycle:

No.	Audit Objective
1	To identify the cyber threats, vulnerabilities and assets relevant to AL-ITTIHAD's environment, and to understand how each threat could exploit a vulnerability to compromise an information asset.
2	To analyze and evaluate the identified risks by determining their likelihood and impact, assigning each a risk level, and prioritizing them so that management attention and budget are directed to the most significant exposures.
3	To support risk treatment by recommending appropriate controls and response measures, and to establish a baseline risk register enabling continuous monitoring and effective management of cybersecurity incidents.

A.3 Scope of Assessment

The assessment covers the complete IT infrastructure of AL-ITTIHAD Multinational Organization as depicted in the network architecture diagram (Figure 1). The scope encompasses all network segments, server assets, end-user devices, network and security devices, the associated software and data they process, and the existing security controls protecting them.

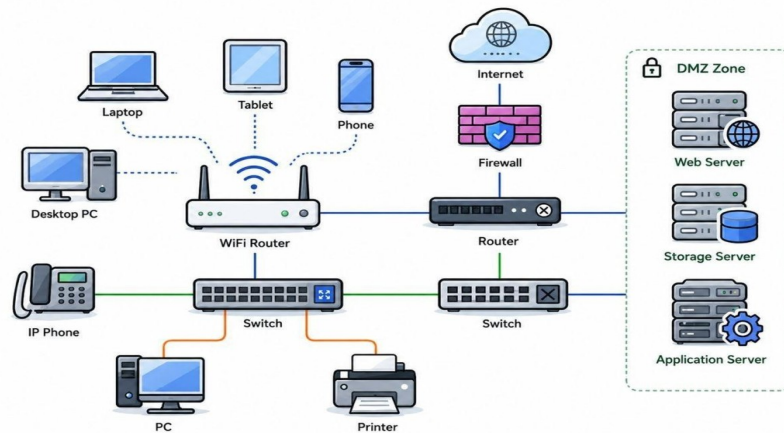


Figure 1: Network Architecture

A.3.1 Network Segments in Scope

Network Segment	Description
Internal LAN	An internal switch and a Wi-Fi router connecting end-user devices (Laptop, Tablet, Phone, Desktop PC, IP Phone, PC, Printer).
DMZ Zone	Publicly accessible servers (Web Server, Storage Server, Application Server), logically and physically separated from the internal network.
Security Perimeter	A Fortinet FortiGate 100F firewall filtering all inbound and outbound traffic between the Internet and the internal/DMZ networks.
External Connectivity	Internet access via ISP, and VPN tunnels provide secure remote access for WFH employees.
Network Infrastructure	A Cisco ISR 4321 router, two Cisco Catalyst 2960 switches and a Cisco RV340W Wi-Fi router responsible for routing and segmentation.

A.3.2 Exclusions (Out of Scope)

The following are explicitly excluded so that the boundaries of the assessment are traceable and auditable: physical penetration testing of facilities; social-engineering exercises against named individuals; source-code review of custom applications; and any third-party or cloud-provider infrastructure beyond AL-ITTIHAD's contractual control.

These exclusions do not imply that the excluded areas are without risk; rather, they fall outside the agreed scope and resource of this engagement and are recommended for coverage in subsequent assessments. Physical security and source-code review are noted as candidate areas for a future phase, since both intersect with risks identified in this report (for example, unauthorized physical access and application input validation).

A.4 Operating Environment

Understanding the internal and external environment ensures that the risks subsequently identified are realistic and grounded in AL-ITTIHAD's actual operating conditions.

Environment Factor	Description
Internal environment	Mixed on-premises and cloud-based systems; a segregated DMZ; centralized IT Department ownership of infrastructure; and a distributed, partially remote workforce.
External environment	An active threat landscape dominated by phishing, ransomware, credential theft and DDoS activity targeting multinational enterprises; reliance on an external ISP and VPN connectivity.
Regulatory / legal	Operations across multiple jurisdictions create simultaneous obligations under regimes such as the PDPA (Malaysia) and the GDPR (EU), among others applicable to AL-ITTIHAD's regions of operation.
Existing controls	A perimeter firewall, VPN-based remote access and periodic security-awareness training are in place, though with varying coverage and effectiveness (detailed in the Control Inventory, Section B).

A.4.1 Regulatory & Compliance Environment

Operating across multiple jurisdictions, AL-ITTIHAD must satisfy several overlapping data-protection and information-security obligations simultaneously. The Malaysian Personal Data Protection Act (PDPA) governs the processing of personal data within Malaysia, while the EU General Data Protection Regulation (GDPR) applies to the personal data of individuals in the European Union and carries substantial penalties for breach. These regimes impose requirements for lawful processing, data-subject rights, breach notification within defined timeframes, and demonstrable accountability. The practical consequence for this assessment is that any risk affecting the confidentiality of personal data carries not only operational and reputational impact but also direct regulatory exposure, which is reflected in the Impact criteria (Section A.7.2) where breaches involving personal data are weighted toward the Major and Critical levels. Maintaining alignment with ISO/IEC 27001 and 27002 supports demonstrable compliance with these obligations and underpins audit and certification readiness.

A.5 Stakeholders

The following stakeholders have an interest in, or responsibility for, the outcomes of this risk assessment. Identifying them at the outset ensures that the right parties are engaged in risk decisions and that accountability for treatment and acceptance is clear.

Stakeholder	Interest / Responsibility in Risk Decisions
Executive Management	Accountable for overall risk appetite and for the formal acceptance of residual risk.
Chief Information Security Officer (CISO)	Owns the information security risk program; approves treatment plans.
IT Department / System Administrators	Custodians of the in-scope assets; implement and operate technical controls.
Internal Cyber Audit Team	Conducts the assessment; maintains the risk register; reports findings to management.
Legal & Compliance	Advises on multi-jurisdictional regulatory obligations (PDPA, GDPR).
Employees / End Users	First line of exposure to phishing and social engineering; subject to awareness obligations.
External Parties (ISP, cloud/SaaS providers)	Provide connectivity and hosted services; introduce third-party dependency risk.

Clear allocation of responsibility is essential to the success of the risk programmed. Executive Management and the CISO hold accountability for risk acceptance and treatment approval respectively; the IT Department is responsible for implementing and operating controls; the Internal Cyber Audit Team is responsible for assessing and reporting risk; and Legal & Compliance is consulted on regulatory matters. End users, while not decision-makers, bear a shared responsibility for vigilant behavior, particularly given the prominence of social-engineering threats identified in this assessment.

A.6 Business Objectives — The CIA Triad

All identified risks are evaluated against the three foundational principles of information security — Confidentiality, Integrity and Availability (the CIA Triad) which serve as the primary criteria for determining business impact.

CIA Principle	Business Objective
Confidentiality	Restrict access to customer data, financial records and intellectual property to authorized personnel only, through access control, encryption and least-privilege policies, preventing unauthorized disclosure.
Integrity	Preserve the accuracy and completeness of data throughout its lifecycle, protecting it from unauthorized modification in transit and at rest, and ensuring critical transactions are auditable.
Availability	Ensure that systems, applications and data remain accessible to authorized users when required, minimizing downtime from attacks, hardware failure or disaster through redundancy and incident-response planning.

Confidentiality. As a multinational handling customer PII, financial records and intellectual property across several jurisdictions, AL-ITTIHAD's confidentiality obligations are both commercial and regulatory. A confidentiality breach would expose the organization to enforcement under regimes such as PDPA and GDPR, contractual penalties and reputational damage. The risk scenarios most relevant to this principle involve credential theft, phishing, interception and unauthorized access.

Integrity. The accuracy of financial transactions, customer records and configuration data is fundamental to trust in the organization's operations. Integrity compromise — through injection, malware or insider tampering — can corrupt records, mislead decision-making and undermine audit assurance, often without immediate detection, which is why integrity-affecting risks are treated as significant even where likelihood is moderate.

Availability. Customer-facing services, remote access for the distributed workforce, and core infrastructure must remain operational. Availability loss — from DDoS, ransomware or single points of failure such as the core router — directly interrupts revenue and productivity and is therefore weighed heavily in the impact criteria for Internet-facing and infrastructure assets.

A.7 Risk Assessment Criteria

This engagement applies to a **semi-quantitative** method consistent with ISO/IEC 27005. Likelihood and Impact are each rated on a 1–5 scale, and the risk score is calculated as the product of the two:

$$\text{Risk Score} = \text{Likelihood Value} \times \text{Impact Value (range 1–25)}$$

Worked example. A threat assessed as Likely (Likelihood = 4) against an asset whose compromise would cause Major business impact (Impact = 4) yields a Risk Score of $4 \times 4 = 16$, which maps to a high-risk level requiring prompt mitigation. The same threat against an asset of only Minor impact (Impact = 2) yields a score of 8, a Low risk that may be monitored. This illustrates how the model allows the same threat to be prioritized differently according to the value of the asset it endangers.

A.7.1 Likelihood Scale

Terminology is aligned to the reference Likelihood Table; descriptions are calibrated to AL-ITTIHAD's operating frequency.

Score	Likelihood Level	Description (AL-ITTIHAD Calibration)
5	Very Likely	Expected to occur frequently or in the near term; multiple past incidents (e.g., several times per year).
4	Likely	Will probably occur in most circumstances; has occurred more than once (at least once per year).
3	Possible	Might occur under specific conditions; has occurred in similar environments (once every 1–3 years).
2	Unlikely	Could occur at some time but not expected in the foreseeable future (once every 3–5 years).
1	Rare	May occur only in exceptional circumstances; has not occurred before.

A.7.2 Impact Scale

Terminology is aligned to the reference Impact Table; AL-ITTIHAD's quantified financial and operational thresholds are retained as its calibration.

Score	Impact Level	Description (AL-ITTIHAD Calibration)
5	Critical	Catastrophic outcome; major or total disruption; financial loss exceeding RM 1 million; regulatory action or a data breach involving thousands of records.
4	Major	Severe disruption (>24 hrs. downtime); breach of policy, contract or compliance; financial loss of RM 100K–1M; loss of sensitive customer/employee data.
3	Moderate	Operational delays (4–24 hrs.); financial loss of RM 10K–100K; partial exposure of internal data; possible lower-tier non-compliance.
2	Minor	Localized disruption (<4 hrs.); minor financial loss (<RM 10K); limited internal data exposure; easily contained.
1	Negligible	Minor inconvenience; no operational or regulatory effect; easily rectified.

A.7.3 Risk Level Definition (Risk Rating Classification)

Risk scores are translated into risk levels using the classification below, aligned to the reference Risk Level Definition Table. Each level carries a color code and a defined action expectation that drives prioritization in Sections C and D.

Risk Score	Risk Level	Color Code	Action Required
20 – 25	Critical	Red	Immediate action; escalate to top management; treat, transfer or avoid.
15 – 19	High	Orange	Mitigate promptly with prioritized controls.
10 – 14	Medium	Yellow	Management review; patch or mitigate within a planned timeframe.
5 – 9	Low	Green	Monitor or accept with minor tuning.
1 – 4	Very Low	Green	Acceptable; monitor periodically.

A.8 Risk Acceptance Criteria

In line with ISO/IEC 27005, the acceptance criteria are defined during Context Establishment so that, once risks are analyzed and evaluated, the organization can consistently decide which risks may be accepted and which must be treated. These criteria express AL-ITTIHAD's risk appetite.

Risk Level	Acceptable?	Justification	Additional Action
Very Low	Yes	Negligible impact; falls within risk appetite.	No action required; monitor periodically.
Low	Yes	Low likelihood and no material regulatory exposure.	Monitor; accept with minor tuning.
Medium	Conditional	Acceptable only with mitigation or documented management sign-off.	Cost–benefit review.
High	No	Above acceptable threshold; may violate SLAs or laws.	Mitigate promptly or escalate.
Critical	No	Unacceptable under any condition.	Immediate response and treatment.

A.9 Assumptions & Constraints

The following assumptions and constraints govern the conduct and interpretation of this assessment:

- The network topology shown in Figure 1 is accurate and reflects the live production environment.
- The organization uses VPN connections to secure remote access for employees working from home (WFH).
- The DMZ is isolated from the internal LAN both logically and physically, and all traffic is filtered by the Fortinet FortiGate 100F firewall.
- AL-ITTIHAD operates in multiple countries and is therefore subject to several data-protection regimes (e.g., PDPA Malaysia, GDPR).
- All IT assets listed in the Asset Inventory (Section A.11) are provisioned and operate in the production environment.
- The assessment is semi-quantitative, based on expert judgment, industry practice and the ISO/IEC 27005 methodology.
- Executive Management and the IT Security Officer are responsible for risk acceptance decisions.
- Periodic cybersecurity awareness training is provided to employees, with varying effectiveness and coverage.

A.10 Reference Standards & Frameworks

This engagement adopts ISO/IEC 27005 as the principal methodology for information security risk management, providing a structured approach to the identification, analysis, evaluation, treatment and monitoring of information security risks. Control selection and implementation are referenced to ISO/IEC 27002. The figure below summarizes the ISO/IEC 27005 risk management process phases applied throughout this report.



Figure 2: ISO/IEC 27005 Risk Management Process Phases

ISO/IEC 27005 was selected in preference to alternative methodologies for several reasons. Compared with the FAIR model, which is strongly quantitative and depends on loss-frequency and loss-magnitude data that AL-ITTIHAD does not yet collect consistently, ISO/IEC 27005 accommodates the semi-quantitative approach appropriate to the organization's current data maturity. Compared with OCTAVE, which is primarily asset- and workshop-driven, and with the NIST Risk Management Framework, which is oriented toward U.S. federal system authorization, ISO/IEC 27005 offers an internationally recognized, governance-driven lifecycle that integrates directly with the ISO/IEC 27001 ISMS the organization is working toward. This alignment maximizes the reusability of the assessment for certification and audit purposes across all of AL-ITTIHAD's jurisdictions.

Standard / Framework	Role in This Engagement
ISO/IEC 27005	Primary methodology governing the end-to-end risk management process (context, identification, analysis, evaluation, treatment, monitoring).
ISO/IEC 27002	Reference catalogue for the selection and implementation of information security controls during risk treatment.
ISO/IEC 27001 (context)	Provides the Information Security Management System (ISMS) context with which the assessment scope is aligned.

A.11 Asset Inventory & Valuation

A complete and accurate asset inventory is the cornerstone of risk identification: an organization cannot protect, or assess risk against, assets it has not catalogued. In accordance with the reference “Possible Information Assets” categories, AL-ITTIHAD's information assets are organized into five categories — Hardware, Software, Data, Network and Services. Each asset is assigned to a unique identifier and a custodian/owner, with its importance to the Confidentiality, Integrity and Availability of the organization's operations reflected throughout the assessment. These identifiers form the single source of truth referenced throughout the Risk Identification (Section B) and Risk Analysis (Section C) phases.

A.11.1 Category 1 — Hardware Assets

Tangible computing, network and peripheral devices that store, process or transmit information. All hardware items are drawn directly from the network architecture (Figure 1). For each asset, the business justification explains why it matters to the organization and why it is included in this risk assessment.

Asset ID	Asset	Model / Brand	Location (Segment)	Business Justification / Reason for Inclusion
HW-01	Web Server	Apache on Dell PowerEdge	DMZ Zone	Hosts the public website and customer-facing online services; its compromise directly disrupts business operations and revenue.
HW-02	Storage Server	Dell PowerVault ME5	DMZ Zone	Stores corporate data, intellectual property and backups; central to data retention, availability and disaster recovery.
HW-03	Application Server	IBM Power S1014 (RHEL)	DMZ Zone	Runs core business application logic and database transactions that support daily operations.
HW-04	Firewall	Fortinet FortiGate 100F	Security Perimeter	Protects the network perimeter and controls all inbound and outbound traffic between the Internet and the internal/DMZ

Asset ID	Asset	Model / Brand	Location (Segment)	Business Justification / Reason for Inclusion
				networks.
HW-05	Router	Cisco ISR 4321 (IOS XE)	Internal/DMZ Gateway	Provides core routing and connectivity between network segments; a single point of failure for connectivity.
HW-06	Wi-Fi Router	Cisco RV340W	Internal LAN	Provides wireless connectivity for mobile and end-user devices on the internal network.
HW-07	Switch (Internal)	Cisco Catalyst 2960	Internal LAN	Interconnects internal wired devices and carries all internal LAN traffic.
HW-08	Switch (DMZ)	Cisco Catalyst 2960	DMZ Zone	Interconnects the DMZ servers and segregates public-facing traffic from the internal network.
HW-09	Laptop	Dell Latitude 5540 (Win 11)	Internal LAN / WFH	Used by employees (including remote/WFH staff) to access corporate systems; a common initial-access target for phishing and malware.
HW-10	Tablet	Samsung Galaxy Tab S9 (Android 14)	Internal LAN	Mobile devices are used by staff to access internal services and communications.
HW-11	Phone	Apple iPhone 15 (iOS 17)	Internal LAN	Mobile devices are used for corporate communication and access to email and applications.
HW-12	Desktop PC	HP EliteDesk 800 (Win 11)	Internal LAN	Workstation used by staff to process business data and access internal systems.
HW-13	IP Phone	Cisco IP Phone 7945 (SCCP)	Internal LAN	Provides VoIP telephony for internal and external business communications.
HW-14	PC	Dell OptiPlex 7090 (Win 11)	Internal LAN	Workstation used by staff for daily operational tasks and access to internal applications.
HW-15	Printer	HP LaserJet Pro M404dn	Internal LAN	Shared network printing devices that processes potentially sensitive HR, legal and financial documents.

The hardware estate concentrates value in the DMZ servers, the perimeter firewall and the core router. These assets are both the most important to operations and the most exposed to external threat, and they accordingly feature prominently in the risk scenarios of Section B. End-user devices, while individually lower in value, are numerous and mobile, making them a frequent entry point for phishing and malware.

A.11.2 Category 2 — Software Assets

Operating systems, firmware, applications and security software running on the hardware estate. Items marked “assumed” are inferred from the environment profile and should be confirmed with the IT Department during validation. The business justification explains why each item is important to operations and why it must be assessed from a cybersecurity perspective.

Asset ID	Software Asset	Description / Host	Business Justification / Reason for Inclusion
SW-01	Apache HTTP Server	Web service software hosting public website (Web Server, HW-01).	Serves the public website; an unpatched or misconfigured web stack would expose customer-facing services to remote exploitation, so it must be assessed.
SW-02	Windows Server 2022	Server operating system (Web & Storage Servers).	Underpins critical servers; its patch and hardening state directly governs the security of the hosts it runs, requiring assessment.
SW-03	Red Hat Enterprise Linux	Server operating system (Application Server, HW-03).	Runs the core application; vulnerabilities or misconfiguration here would expose business processing and data, so it must be assessed.
SW-04	Database Management System (assumed)	Back-end database storing business/customer data (Application Server).	Holds the organization's most sensitive data; a primary target for injection, theft and tampering, making it essential to assess.
SW-05	FortiOS	Firewall operating system / firmware (FortiGate 100F).	Enforces all perimeter security policy; a flaw or outdated firmware could neutralize the principal boundary control, so it must be assessed.
SW-06	Cisco IOS XE	Router operating system (Cisco ISR 4321).	Governs routing integrity and network availability; compromise enables traffic manipulation, so it requires security assessment.
SW-07	Cisco IOS	Switch operating system (Catalyst 2960 × 2).	Supports internal connectivity and segmentation; weaknesses enable lateral movement, so it must be assessed.
SW-08	Microsoft Windows 11	End-user operating system (Laptop, Desktop PC, PC).	Runs on numerous endpoints; its configuration and patch state determine endpoint exposure to malware and exploitation, requiring assessment.
SW-09	Mobile OS (Android 14 / iOS 17)	End-user mobile operating systems (Tablet, Phone).	Operates mobile endpoints accessing corporate resources; outdated versions

Asset ID	Software Asset	Description / Host	Business Justification / Reason for Inclusion
			broaden the attack surface, so they are assessed.
SW-10	VPN Client / Remote-Access Software	Secure remote connectivity for WFH employees.	Provides the trusted gateway for remote access; a key entry point to the internal network, making its security critical to assess.
SW-11	Endpoint Protection / Antivirus (assumed)	Malware detection and response on endpoints/servers.	Detects and contains malware; gaps in coverage directly raise the likelihood of successful compromise, so it must be assessed.
SW-12	Backup Software (assumed)	Scheduled backup of corporate data (Storage Server).	Enables recovery from data loss or ransomware; its integrity and configuration determine whether recovery is assured, requiring assessment.

Software assets determine the security posture of the hardware they run on; unpatched operating systems, firmware and applications are among the most exploited weaknesses. The server operating systems, the firewall OS and the database management system are the most consequential software assets because they mediate access to the organization's most sensitive data and services.

A.11.3 Category 3 — Data Assets

Information is held, processed or transmitted by the organization. Each data asset is assigned a classification reflecting its sensitivity, and a CIA priority that is now explained in full — describing why Confidentiality, Integrity and (where applicable) Availability matter for that asset. This reasoning directly informs the priorities used during risk analysis.

Asset ID	Data Asset	Repository / Location	Classification	CIA Priority & Justification
DA-01	Customer PII	Application Server / DBMS	Restricted	Priority: C-I Confidentiality: Prevent unauthorized disclosure of personal data and meet PDPA/GDPR obligations. Integrity: Ensure customer records remain accurate and unaltered for reliable service and compliance. Availability: Authorized staff can access records when required to serve customers.
DA-02	Employee / HR records	Application Server / Storage	Confidential	Priority: C-I Confidentiality: Protect employee personal data from unauthorized disclosure. Integrity: Maintain accurate HR, payroll and personnel records.

Asset ID	Data Asset	Repository / Location	Classification	CIA Priority & Justification
				Availability: HR staff need timely access for personnel operations.
DA-03	Financial records	Application Server / Storage	Restricted	Priority: C-I Confidentiality: Prevent disclosure of sensitive financial information. Integrity: Guarantee accuracy of financial transactions and reporting for audit assurance. Availability: Finance staff require access for reporting and daily operations.
DA-04	Intellectual property / documents	Storage Server	Confidential	Priority: C-I Confidentiality: Protect proprietary documents and intellectual property from disclosure to competitors. Integrity: Preserve the accuracy and authenticity of corporate documents. Availability: Authorized users need access to support ongoing business activities.
DA-05	Authentication credentials & keys	All systems / VPN	Restricted	Priority: C Confidentiality: Disclosure of credentials enables full system compromise; confidentiality is paramount. Integrity: Credentials and keys must remain unaltered to preserve trust in authentication. Availability: Must remain available to authentication services to avoid lockouts.
DA-06	System & audit logs	Servers / network devices	Internal	Priority: I-A Confidentiality: Logs are internal but may contain sensitive operational detail requiring protection. Integrity: Logs must be tamper-proof to support investigation and accountability. Availability: Logs must be available for monitoring, detection and forensic analysis.
DA-07	Backup data sets	Storage Server (PowerVault ME5)	Confidential	Priority: A-I Confidentiality: Backups replicate sensitive data and must be protected from disclosure. Integrity: Backups must be intact and uncorrupted to guarantee reliable recovery. Availability: Backups must be available (and ideally immutable) to restore operations after an incident.
DA-08	Device configuration data	Firewall / Router / Switches	Confidential	Priority: I Confidentiality: Configurations may reveal the security posture and must be protected from disclosure. Integrity: Configurations must remain accurate so devices operate securely and correctly. Availability: Configurations must be available for recovery and change management.
DA-09	Email / communications data	Mail service / endpoints	Internal	Priority: C-A Confidentiality: Communications may contain sensitive or personal information requiring protection. Integrity: Messages should remain unaltered to preserve trust in communications. Availability: Email must be available for day-to-day business communication.

Data is the ultimate target of most cyber threats and the focus of the organization's regulatory obligations. The classification assigned to each data asset — from Internal through Confidential to Restricted — drives the confidentiality weighting applied during impact assessment, with customer PII, financial records and credentials representing the most consequential holdings.

A.11.4 Category 4 — Network Assets

Logical and physical network components, segments and connectivity services that enable communication between assets, including the boundaries that enforce segregation.

Asset ID	Network Asset	Description	Business Justification / Reason for Inclusion
NW-01	Internal LAN	Wired/wireless local network connecting all internal end-user devices.	Supports daily internal communication and connects employees to business systems; weaknesses could allow disruption or lateral movement.
NW-02	DMZ Network Segment	Isolated segment hosting public-facing servers, separated from the LAN.	Protects public-facing services from the internal network; its security is essential to reduce exposure from internet-based attacks.
NW-03	Wireless Network (Wi-Fi)	Wireless access provided by the Cisco RV340W for mobile endpoints.	Enables mobile connectivity for staff devices; weak wireless security could expose credentials and internal traffic.
NW-04	VPN Tunnels / Remote Access	Encrypted channels provide WFH employees with secure access to internal resources.	Supports remote work and secure access; compromised VPN access could give attackers trusted entry into internal systems.
NW-05	WAN / Internet Connectivity	External link via the ISP connecting the organization to the public Internet.	Provides external connectivity for business operations and public services; failure or attack could affect availability.
NW-06	Security Perimeter Boundary	Firewall-enforced boundary controlling inbound/outbound traffic.	Acts as the main network protection boundary; misconfiguration could expose internal and DMZ systems to unauthorized traffic.
NW-07	VLAN Segmentation	Logical segmentation across the Catalyst switches separating traffic domains.	Limits traffic between network areas and reduces lateral movement; poor segmentation increases the impact of any compromise.

Network assets provide the connectivity that enables the organization to operate and, simultaneously, the pathways an attacker uses to move toward valuable targets. The VPN, the security perimeter and the segmentation (or lack of it) between segments are pivotal: weaknesses here convert a localized compromise into an organization-wide exposure.

A.11.5 Category 5 — Service Assets

Business and technical services delivered to internal and external users by the underlying hardware, software and network assets. Service availability requirements indicate the tolerance of each service in downtime.

Asset ID	Service Asset	Description / Dependent Assets	Availability Requirement
SV-01	Public Website / Web Application	Customer-facing site (HW-01, SW-01).	High (24×7)
SV-02	File Storage & Backup Service	Centralized storage and recovery (HW-02, SW-12).	High
SV-03	Business Application Service	Core operational application logic (HW-03, SW-04).	High
SV-04	Email / Webmail Service	Corporate messaging for staff communications.	Medium
SV-05	DNS Service	Name resolution for internal and external access.	High
SV-06	VPN Remote-Access Service	Secure remote connectivity for WFH workforce (NW-04, SW-10).	High
SV-07	VoIP / IP Telephony Service	Voice communications over the IP Phone estate (HW-13).	Medium
SV-08	Network Printing Service	Shared document printing (HW-15).	Low
SV-09	Directory / Authentication Service (assumed)	Centralized user authentication and access control.	High
SV-10	Cloud / SaaS Services	Externally hosted cloud-based business systems.	Medium

Services represent the business functions that the underlying assets deliver to users and customers; their availability requirements express how much downtime each can tolerate. The public website, application, storage, DNS and VPN services are the most availability-sensitive, and their disruption maps directly to the operational and financial impact criteria defined in Section A.7.

A.11.6 Detailed Asset Specifications

To support precise identification, configuration management and incident response, the following tables record the technical specifications of the in-scope hardware, including operating system/firmware, network addressing and connectivity. In line with the supervisor's request, every device now carries a unique Asset ID and a Physical Location, providing the granularity required to trace any identified risk to a specific, uniquely addressable and physically locatable device.

End-User Devices

Asset ID	Device	Model	OS	MAC Address	Serial No.	Connectivity	Physical Location
HW-09	Laptop	Dell Latitude 5540	Windows 11	00:1A:2B:3C:4D:10	LT01231101	Wireless	Second Floor – IT Department
HW-10	Tablet	Samsung Galaxy Tab S9	Android 14	00:1A:2B:3C:4D:11	TB01231102	Wireless	First Floor – Administration Office
HW-11	Phone	Apple iPhone 15	iOS 17	00:1A:2B:3C:4D:12	PH01231103	Wireless	First Floor – Administration Office
HW-12	Desktop PC	HP EliteDesk 800	Windows 11	00:1A:2B:3C:4D:13	PC01231104	Wireless	First Floor – Finance Department
HW-13	IP Phone	Cisco IP Phone 7945	SCCP Firmware	00:1A:2B:3C:4D:14	IP01231105	Wired	First Floor – Finance Department
HW-14	PC	Dell OptiPlex 7090	Windows 11	00:1A:2B:3C:4D:15	PC01231106	Wired	First Floor – Administration Office
HW-15	Printer	HP LaserJet Pro M404dn	Embedded	00:1A:2B:3C:4D:16	PR01231107	Wired	First Floor – Administration Office

DMZ Zone Servers

Asset ID	Device	Model	OS	MAC Address	Serial No.	Physical Location
HW-01	Web Server	Apache HTTP Server	Windows Server 2022	00:1A:2B:3C:4D:5E	WS01231102	Server Room – Ground Floor
HW-02	Storage Server	Dell PowerVault ME5	Windows Server 2022	00:11:22:33:44:66	SS01231103	Server Room – Ground Floor
HW-03	Application Server	IBM Power S1014	Red Hat Enterprise Linux	00:11:22:33:44:77	AS01231104	Server Room – Ground Floor

Network & Security Devices

Asset ID	Device	Model	OS / Firmware	MAC Address	Serial No.	Physical Location
HW-04	Firewall	Fortinet FortiGate 100F	FortiOS	00:1C:2D:3E:4F:5A	FW12345678	Server Room – Ground Floor
HW-05	Router	Cisco ISR 4321	IOS XE	00:3A:4B:5C:6D:7E	RT234567890	Network Rack Room – Ground Floor
HW-06	Wi-Fi Router	Cisco RV340W	Cisco Router OS	00:2A:3B:4C:5D:01	WR01231201	Network Rack Room – Ground Floor
HW-07	Switch (Internal)	Cisco Catalyst 2960	IOS	00:4B:5C:6D:7E:01	SW01231301	Network Rack Room – Ground Floor

A.11.7 Asset Ownership Matrix

Asset ID	Asset Name	Asset Category	Asset Owner	Custodian	Business Function Supported	Ownership Justification
HW-01	Web Server	Hardware	CISO	IT Infrastructure Team	Hosts the public website and customer-facing services (SV-01)	Internet-facing and business-critical; senior security accountability is warranted given its direct exposure and revenue role.
HW-02	Storage Server	Hardware	IT Infrastructure Manager	IT Infrastructure Team	Corporate data storage and backup (SV-02)	Central repository for corporate data and backups; infrastructure leadership owns its availability and recoverability.
HW-03	Application Server	Hardware	IT Infrastructure Manager	Database Administrator	Core business application and database processing (SV-03)	Hosts business logic and restricted data; owned by infrastructure leadership with database custody for daily operation.
HW-04	Firewall	Hardware	CISO	IT Security Team	Perimeter security boundary (NW-06)	The principal perimeter control; security leadership must be accountable for the policy it enforces.
HW-05	Router	Hardware	IT Infrastructure Manager	Network Administrator	Core routing and connectivity (NW-05)	A single point of failure for connectivity; owned by infrastructure leadership and operated by the network team.
HW-06	Wi-Fi Router	Hardware	IT Infrastructure Manager	Network Administrator	Wireless connectivity for mobile devices (NW-03)	Network access assets whose configuration is maintained day-to-day by the network team.
HW-07	Switch (Internal)	Hardware	IT Infrastructure Manager	Network Administrator	Internal LAN connectivity (NW-01)	Backbone of internal connectivity; network team manages configuration and segmentation.
HW-08	Switch (DMZ)	Hardware	IT Infrastructure Manager	Network Administrator	DMZ connectivity and segregation (NW-02)	Segregates public-facing traffic; owned by infrastructure leadership with network-team custody.
HW-09	Laptop	Hardware	IT Manager	IT Support Team	Employee and remote access to corporate systems	End-user device fleet; managed and provisioned by IT support under IT management ownership.
HW-10	Tablet	Hardware	IT Manager	IT Support Team	Mobile access to internal services	End-user mobile device administered by IT support.
HW-11	Phone	Hardware	IT Manager	IT Support Team	Mobile corporate communication and application access	End-user mobile device administered by IT support.
HW-12	Desktop PC	Hardware	IT Manager	IT Support Team	Processing of business data and access to internal systems	Standard workstation managed by IT support.
HW-13	IP Phone	Hardware	IT Manager	IT Infrastructure Team	VoIP and IP telephony (SV-07)	Telephony endpoint operated by the infrastructure team under IT management ownership.
HW-14	PC	Hardware	IT Manager	IT Support Team	Daily operational tasks and internal application access	Standard workstation managed by IT support.
HW-15	Printer	Hardware	IT Manager	IT Support Team	Shared network printing (SV-08)	Shared peripheral handling of sensitive documents; administered by IT support.
NW-01	Internal LAN	Network	IT Infrastructure Manager	Network Administrator	Internal connectivity for all end-user devices	Core internal network owned by infrastructure leadership and operated by the network team.
NW-02	DMZ Network Segment	Network	CISO	Network Administrator	Isolated hosting of public-facing servers	Security-sensitive boundary segment; owned by the CISO to preserve its segregation from the LAN.



Asset ID	Asset Name	Asset Category	Asset Owner	Custodian	Business Function Supported	Ownership Justification
NW-04	VPN Tunnels / Remote Access	Network	CISO	Security Operations Team	Secure remote access for the WFH workforce (SV-06)	A trusted entry point into the internal network; security leadership owns the remote-access trust boundary.
DA-01	Customer PII	Data	Data Protection Officer	Database Administrator	Customer records supporting service delivery and compliance	Regulated personal data; the DPO is accountable under PDPA and GDPR, with the DBA as technical custodian.
DA-03	Financial records	Data	Finance Department Head	Database Administrator	Financial transactions and reporting	The business owner of financial data is the Finance function; the DBA maintains the data technically.
DA-05	Authentication credentials & keys	Data	CISO	IT Security Team	Authentication across all systems and the VPN	Security-critical data whose disclosure enables system-wide compromise; owned by the CISO.

The matrix confirms that accountability for every major asset is clearly allocated and that a consistent governance pattern applies: the CISO owns security-defining assets such as the firewall, the DMZ segment, the VPN and authentication data; infrastructure and IT management own the operational hardware and network estate; and business and data-protection roles own the data assets for which they are legally and operationally responsible. In all cases ownership is separated from custody, so that strategic accountability and day-to-day administration are held by distinct roles. This separation strengthens cybersecurity accountability and provides the ownership foundation on which the risk owners cited in the Risk Register and the responsibilities in the Risk Treatment Plan are based.

A.12 Asset Valuation & Criticality Methodology

Asset valuation determines the relative importance of each asset to the organization and is a prerequisite for meaningful impact assessment. AL-ITTIHAD values assets on a three-tier criticality scale derived from the consequence to Confidentiality, Integrity and Availability should the asset be compromised. The criticality assigned to each asset directly informs the Impact ratings applied during Risk Analysis in Section C.

Criticality	Valuation Basis
High	Assets essential to core operations, holding restricted/confidential data or providing services whose loss causes Major or Critical business impact (e.g., servers, firewall, core router, VPN).
Medium	Assets are important to operations whose compromise causes moderate, contained disruption (e.g., Wi-Fi router, managed endpoints, switches).
Low	Supporting assets with limited operational impact if compromised (e.g., printer, IP phone, tablet).

Applying this methodology across the inventory, the organization's asset base is weighted toward High-criticality infrastructure: the DMZ servers, perimeter firewall, core router and remote-access service together represent the concentration of value that most attracts threat activity and that the risk scenarios in Section B therefore prioritize.

A.12.1 Asset Inventory Summary

The table below summarizes the asset inventory by category and criticality, providing management with an at-a-glance view of where the organization's most critical assets are concentrated.

Category	Total	High	Medium	Low
Hardware	15	7	4	4
Software	12	8	2	2
Data	9	4	4	1
Network	7	5	2	0

Category	Total	High	Medium	Low
Services	10	6	3	1
Total	53	30	15	8

The predominance of High-criticality assets — over half of the inventory — underscores why a structured, prioritized risk program is essential: the organization cannot treat all assets equally and must direct its controls to the concentration of value identified here.

This concludes the Context Establishment phase. The scope, environment, stakeholders, business objectives, risk criteria, acceptance thresholds and a fully valued five-category asset inventory now provide the stable foundation required for the next phase. Section B proceeds to identify the specific threats, vulnerabilities and existing controls associated with these assets and to express each as a structured risk scenario.

Section B: Risk Identification

Building on the context established in Section A, the Risk Identification phase (Phase 2 of ISO/IEC 27005) determines what could happen to cause a loss to the organization. It systematically identifies the threats that could affect AL-ITTIHAD's assets, the vulnerabilities those threats could exploit, the existing controls already in place, and the consequences of compromise. The output of this phase is a set of structured risk scenarios — each pairing a threat with a vulnerability against a specific asset — which becomes the unit of analysis in Section C. No risk scoring is performed here; the objective is comprehensive, traceable identification.

B.1 Risk Identification Methodology

The identification followed a repeatable, asset-driven sequence so that each resulting scenario is traceable back to the inventory and forward to the analysis:

Step	Action Performed
1	Confirm the in-scope assets from the Section A inventory and select those exposed to cyber threat.
2	Identify relevant threat sources and threat events applicable to each asset (B.3).
3	Identify the vulnerabilities that each threat could exploit (B.4).
4	Document the existing controls and their coverage (B.5).
5	Construct structured risk scenarios pairing threat × vulnerability × asset, with affected CIA and consequence (B.6).
6	Summarize the identified risks (B.7) and map their CIA impact (B.8) as input to analysis and the risk register (Section D).

B.2 Asset Identification (Risk-Relevant Subset)

The following risk-relevant assets, drawn from the Section A inventory, anchor the scenarios developed in this section.

Asset ID	Asset	Category / Location	Role in Risk Scenarios
HW-01	Web Server	Hardware / DMZ	Internet-facing target for DDoS and exploitation.
HW-02	Storage Server	Hardware / DMZ	Repository of corporate data and

Asset ID	Asset	Category / Location	Role in Risk Scenarios
			backups; ransomware target.
HW-03	Application Server	Hardware / DMZ	Fronts customer/business data; injection target.
HW-04	Firewall (FortiGate 100F)	Hardware / Perimeter	Principal boundary control; zero-day target.
HW-05	Router (Cisco ISR 4321)	Hardware / Gateway	Core routing single point of failure; brute-force target.
HW-06	Wi-Fi Router (RV340W)	Hardware / Internal LAN	Wireless access; MitM target.
HW-07	Internal Switch (Catalyst 2960)	Hardware / Internal LAN	Carries internal traffic; malware-propagation path.
HW-13	IP Phone (7945)	Hardware / Internal LAN	VoIP endpoint; insider-interception target.
HW-15	Printer (LaserJet M404dn)	Hardware / Internal LAN	Shared printing; document-interception target.
NW-04	VPN / Remote Access	Network	Trusted remote entry point; credential-theft target.
HW-09/11/12/14	Employee Endpoints	Hardware / Internal LAN	Human-facing entry points for phishing and social engineering.

B.3 Threat Source Identification

Threat sources were identified with reference to the standard categories in ISO/IEC 27005 and assessed for their relevance to AL-ITTIHAD's multinational, Internet-facing profile.

Threat Source Category	Relevance to AL-ITTIHAD
Malicious Outsiders	Highly relevant — primary external factors driving DDoS, ransomware, injection and credential attacks against Internet-facing assets.
Malicious Insiders	Relevant — employees or contractors abusing legitimate access to intercept or exfiltrate data.
Unintentional Insiders	Highly relevant — staff inadvertently introducing malware or falling for phishing lures.
Social Engineers	Highly relevant — exploit the human layer through phishing, pretexting and impersonation.
Nation-State / APT	Possible — capable of zero-day exploitation against high-value multinational targets.
Hacktivists	Possible — ideologically motivated disruption such as DDoS or defacement against multinationals.
Technological / System Failure	Relevant — hardware/software faults and misconfiguration that enable outages or exploitation.
Natural / Environmental	Lower relevance to this cyber scope — addressed through business-continuity and disaster-recovery planning.

B.3.1 Threat Event Catalogue

Twelve threat events were catalogued, each linked to the CIA dimension it primarily affects and to its principal threat source.

ID	Threat Event	CIA Impact	Threat Source	Description
T-01	DDoS Attack	Availability	Malicious Outsiders	Flooding public services to exhaust resources and deny access.
T-02	Phishing / Spear-Phishing	Confidentiality	Social Engineering	Fraudulent emails to harvest credentials or deliver malware.
T-03	Ransomware	Availability / Integrity	Malicious Outsiders	Malware encrypting data and backups for extortion.
T-04	SQL Injection	Confidentiality / Integrity	Malicious Outsiders	Crafted input against a web/app to read or alter the database.
T-05	Man-in-the-Middle	Confidentiality	Outsiders / Insiders	Interception or relay of traffic between endpoints.
T-06	Insider Threat	Confidentiality / Integrity	Malicious Insiders	Abuse of legitimate access to disclose or alter data.
T-07	Brute Force / Password Attack	Confidentiality / Availability	Malicious Outsiders	Automated credential guessing against exposed interfaces.
T-08	Malware / Trojan	Integrity / Availability	Unintentional Insiders	Malicious code introduced via media/download, spreading laterally.
T-09	Data Leakage / Exfiltration	Confidentiality	Insiders / Outsiders	Unauthorized transfer of sensitive data out of the organization.
T-10	Zero-Day Exploit	Confidentiality / Availability	Outsiders / Tech. Failure	Exploitation of an unpatched, previously unknown vulnerability.
T-11	Social Engineering	Confidentiality	Social Engineering	Manipulation (e.g., impersonating IT) to extract secrets or access.
T-12	VPN Credential Theft	Confidentiality	Malicious Outsiders	Theft or guessing of VPN credentials for trusted remote access.

B.3.2 Detailed Threat Profiles

Each threat event is profiled below by likely actor and method, the assets it targets, and its potential consequence — providing the rationale that informs the likelihood and impact judgments in Section C.

Threat	Actor & Method	Assets Targeted	Potential Consequence
DDoS (T-01)	Botnet operator floods public IPs with traffic.	Web Server; perimeter	Loss of website availability; revenue and reputation damage.
Phishing (T-02)	Social engineers send deceptive email with link/attachment.	Employee endpoints	Credential compromise; foothold for wider intrusion.
Ransomware (T-03)	Outsider deploys encrypting malware after initial access.	Storage Server; backups	Data and backups encrypted; operational halt; extortion.
SQL Injection (T-04)	Attacker submits crafted SQL via web form.	Application Server; DBMS	Theft and tampering of customer/financial data.
MitM (T-05)	Adversary intercepts traffic over Wi-Fi or unsecured services.	Wi-Fi network; printer	Interception of credentials and sensitive data.
Insider (T-06)	Disgruntled employee abuses internal access.	VoIP; internal data	Covert interception or alteration of communications/data.
Brute Force (T-07)	Automated guessing against management interfaces.	Router; admin accounts	Administrative compromise; traffic manipulation/outage.
Malware/Trojan (T-08)	User runs malicious file from media/download.	Endpoints; internal LAN	Lateral spread; integrity and availability loss across estate.
Data Leakage (T-09)	Insider or outsider exfiltrates sensitive data.	Data stores; endpoints	Confidentiality breach; regulatory exposure.
Zero-Day (T-10)	Advanced actor exploits an unpatched flaw.	Firewall; servers	Perimeter compromise; wide internal access.
Social Engineering (T-11)	Attacker impersonates IT support by phone/message.	Employees; endpoints	Disclosed credentials; unauthorized access pivot.
VPN Credential Theft (T-12)	Attacker brute-forces or stuffs VPN logins.	VPN; internal systems	Trusted internal-equivalent access; org-wide breach.

B.4 Vulnerability Identification

Twelve vulnerabilities were identified across technical, configuration, process and human categories. Each is mapped to the assets it most effects and forms the exploitable weakness within a risk scenario.

ID	Affected Asset(s)	Vulnerability	Category	Description
V-01	Servers, endpoints	Outdated / unpatched software	Technical	Systems running software with known, unpremeditated vulnerabilities.
V-02	Wi-Fi Router / clients	Weak or default Wi-Fi credentials	Configuration	Wireless use of default/weak keys or lacking enterprise authentication.
V-03	Firewall	Misconfigured firewall rules	Configuration	Overly permissive or poorly maintained perimeter rule base.
V-04	Storage Server	Lack of encryption at rest	Technical	Stored data unencrypted, exposing it if storage is accessed.
V-05	Servers, network devices	Insufficient logging & monitoring	Process / Technical	Limited detection and alerting, delaying incident discovery.
V-06	Application Server	Improper input validation	Technical	Application accepts unsensitized input, enabling injection.
V-07	VPN, router, accounts	Weak password policy	Configuration / Process	No complexity, lockout or multi-factor enforcement.
V-08	Internal LAN, VoIP	Lack of network segmentation	Configuration	Flat network allows lateral movement between segments.
V-09	Employees / endpoints	Low cybersecurity awareness	Human / Training	Staff are susceptible to phishing and social-engineering manipulation.
V-10	Storage Server / backups	Inadequate backup & recovery	Process	Backups not immutable or tested, undermining reliable recovery.
V-11	VPN / remote access	Unrestricted remote access	Configuration	Remote access without MFA or session controls.
V-12	Printer	Unsecured network printing services	Configuration	Printer management/printing without authentication or isolation.

B.4.1 Vulnerability Profiles

The principal vulnerabilities exploited in this assessment's scenarios are profiled below by nature, typical exploitation route and the indicators an auditor would look for.

Vulnerability	Nature	Typical Exploitation	Audit Indicators
Misconfigured firewall rules (V-03)	Permissive/legacy rules at the perimeter.	Unfiltered floods or traversal of the boundary.	Any-any rules; no rate-limiting; stale objects.
Improper input validation (V-06)	Application trusts unsensitized input.	Injected SQL reaches the database.	No WAF; absent parameterized queries.
Weak password policy (V-07)	No complexity, lockout or MFA.	Brute-force or credential-stuffing success.	Single-factor logins; no lockout thresholds.
No segmentation (V-08)	Flat internal network.	Lateral movement after a single compromise.	Shared VLANs; no NAC; voice/data mixed.
Low awareness (V-09)	Human susceptibility to deception.	Clicked lures; disclosed credentials.	Inconsistent training; no phishing simulations.
No encryption at rest (V-04)	Store data in plaintext.	Readable data and corruptible backups.	Unencrypted volumes; mutable backups.
Unsecured printing (V-12)	Open printer management/printing.	Access to spoiled or forwarded documents.	No admin password; printer on shared VLAN.

B.5 Existing Control Inventory

The controls already present in AL-ITTIHAD's environment were inventoried by control type so that the risk scenarios reflect residual exposure rather than an unprotected baseline. Coverage is characterized honestly, as several controls are partial.

Control Type	Controls Present	Coverage / Effectiveness
Preventive	Perimeter firewall (FortiGate 100F); VPN encryption; security-awareness training.	Partial — no MFA; segmentation and rate-limiting gaps.
Detective	Basic device logging.	Weak — no centralized SIEM or active monitoring evidenced.
Corrective	Ad-hoc backups.	Partial — backups not



Control Type	Controls Present	Coverage / Effectiveness
		immutable/tested; no formal incident-response plan.
Administrative	Security policies; periodic training.	Partial — inconsistent coverage and enforcement.
Physical	Server-room access control (assumed).	Out of testing scope; assumed adequate.
Technical	Endpoint OS protections; firewall filtering.	Partial — EDR, WAF and NAC not evidenced.

The control inventory reveals a perimeter-weighted posture: preventive boundary controls exist, but detective and corrective capabilities — monitoring, immutable backups, incident response — are weak, and key compensating controls such as MFA and network segmentation are absent. These gaps are the recurring reason that several scenarios in Section C are driven to High or Critical levels despite the presence of a capable firewall.

B.5.1 Attack Surface Summary

The attack surface is the totality of points at which an attacker could attempt to enter, affect or extract data from AL-ITTIHAD's environment. Summarizing it consolidates the threats and assets already identified in this section into a clear view of where exposure exists and provides the bridge between threat identification and the structured risk scenarios developed in Section B.6. The surface is examined in two parts — external and internal — using only the assets and threats already recorded in the report.

External Attack Surface

The external attack surface comprises the assets reachable from the Internet or from outside the office perimeter. The Web Server (HW-01) in the DMZ is exposed by design, since it must serve the public website (SV-01); this same reachability makes it the target of the DDoS scenario (RS-01). The Application Server (HW-03), reachable through its public web forms, presents an input-driven surface exploited in the SQL Injection scenario (RS-04). The VPN / Remote Access service (NW-04) deliberately extends the trust boundary beyond the office to support the WFH workforce, and its login interface is the entry point for VPN credential theft (RS-07). The FortiGate firewall (HW-04) is itself Internet-facing as the perimeter device and is

therefore the surface for the zero-day scenario (RS-08), while the Storage Server (HW-02) is reachable within the DMZ and is the ultimate target of the ransomware scenario (RS-03).

These assets are exposed because they provide services that, by their nature, must be accessible from outside the organization. The attack opportunities they present include volumetric denial of service, injection through public inputs, credential-based intrusion over remote access, and exploitation of the perimeter device itself. The security implication is that the external surface concentrates the organization's highest-likelihood and highest-impact risks, which is why the perimeter-facing scenarios dominate the Critical and High bands of the risk analysis.

Internal Attack Surface

The internal attack surface comprises assets reachable once an actor is inside the network, whether a malicious insider, a compromised account, or malware that has gained a foothold. The Internal LAN and its switches (HW-07, NW-01) carry all internal traffic and, because the network is not segmented, provide the propagation path exploited in the malware scenario (RS-06). The Wi-Fi network (HW-06) is reachable by anyone within wireless range and is the surface for the man-in-the-middle scenario (RS-05). The Router (HW-05) exposes a management interface reachable from internal segments, exploited in the brute-force scenario (RS-10). Employee endpoints (HW-09/HW-11/HW-12/HW-14) are the human-facing surface targeted by phishing (RS-02) and social engineering (RS-11). The IP Phone estate (HW-13) on the unsegmented voice network is the surface for the insider interception scenario (RS-09), and the shared Printer (HW-15) presents the unsecured-printing surface of the document-interception scenario (RS-12).

Internally, the principal attack opportunities are insider abuse of legitimate access, interception on shared media, and — most significantly — lateral movement. Because the internal network lacks segmentation (V-08), a single compromised endpoint or introduced Trojan can traverse the flat network to reach critical servers, converting a localized event into an estate-

wide one. The internal surface therefore amplifies the consequence of any successful external intrusion, making segmentation a recurring priority in the treatment plan.

Attack Surface Analysis Table

The table below maps each exposed asset to its exposure type, the entry points an attacker would use, the primary threat already identified against it, and the controls currently in place.

Asset	Exposure Type	Potential Entry Point	Primary Threat	Existing Controls
Web Server (HW-01)	External	Public website (HTTP/S)	DDoS Attack (T-01)	Perimeter firewall filtering; no DDoS scrubbing or rate-limiting.
Application Server (HW-03)	External	Public web-form inputs	SQL Injection (T-04)	Network perimeter controls only; no WAF or input-validation assurance.
VPN / Remote Access (NW-04)	External	VPN login interface	VPN Credential Theft (T-12)	Encrypted VPN transport; no MFA, lockout or session monitoring.
Firewall (HW-04)	External	Internet-facing management/data plane	Zero-Day Exploit (T-10)	FortiGate perimeter control with a scheduled update window and active vendor support.
Storage Server (HW-02)	External (DMZ)	DMZ services / shares	Ransomware (T-03)	Ad-hoc backups; no immutable/tested backups; no EDR/IR.
Wi-Fi Router / Clients (HW-06)	Internal	Wireless association range	Man-in-the-Middle (T-05)	Configurable wireless encryption; enterprise auth not confirmed.
Internal Switches / LAN (HW-07)	Internal	Removable media / malicious download	Malware / Trojan (T-08)	Endpoint OS protections; no VLAN segmentation or NAC.
Router (HW-05)	Internal	Router management interface	Brute Force / Password Attack (T-07)	Routing enforced; no account lockout, MFA or out-of-band management.
Employee Endpoints (HW-09/12/14)	Internal (user)	Email / web links	Phishing / Spear-Phishing (T-02)	Periodic awareness training (inconsistent); basic email filtering; no MFA.
Employee Endpoints / Mobile (HW-09/11)	Internal (user)	Phone / Message pretext	Social Engineering (T-11)	Partial awareness training; no verification procedures.
IP Phone / Telephony (HW-13)	Internal	Unsegmented voice network	Insider Threat (T-06)	Logical/physical DMZ separation; limited voice/data VLAN and logging.
Printer (HW-15)	Internal	Printer management interface	Man-in-the-Middle (T-05)	On internal network; no management authentication or VLAN isolation.

Attack Surface Discussion

The analysis shows that AL-ITTIHAD's most exposed assets are those that combine reachability with high value: the public Web and Application Servers, the VPN remote-access service and the perimeter firewall. These external-facing assets present the highest-risk entry points because they are continuously reachable, attract opportunistic and targeted attacks, and front either revenue-generating services or the trusted path into the internal network. The VPN is a critical entry point, since a single credential compromise grants internal-equivalent access; this is reflected in its Critical rating (RS-07).

The relationship between the attack surface and the identified risks is direct: every entry point in the table corresponds to a risk scenario already analyzed in Section C, and the severity of each risk tracks the exposure and value of its entry point. The external surface concentrates the Critical and High risks, while the internal surface, though generally lower in initial likelihood, governs the potential for lateral movement that magnifies impact. This confirms that reducing the attack surface — by hardening the perimeter, enforcing MFA on remote access, and segmenting the internal network — addresses the organization's most significant exposures at their point of origin and underpins the prioritization adopted in the risk treatment plan.

B.6 Risk Scenario Development

Each identified risk is expressed as a structured scenario that pairs a threat event with a vulnerability against a specific asset, states the affected CIA dimension and existing controls, and concludes with a formal risk statement. Twelve scenarios (RS-01 to RS-12) were developed; all are carried forward unchanged into the analysis. Each scenario is followed by a short attack narrative and a statement of business consequences.

RS-01: Web Server DDoS (Availability)

Scenario ID	RS-01
Asset	Web Server (DMZ) — HW-01
Threat Event	T-01 — DDoS Attack [Source: Malicious Outsiders]
Vulnerability	V-03 — Misconfigured Firewall Rules [Category: Configuration]

Affected Service	SV-01 Public Website / Web Application
CIA Impact	Availability
Existing Controls & Gaps	Perimeter firewall filtering in place; no upstream DDoS scrubbing, rate-limiting or capacity reserve; detective monitoring weak.
Risk Statement	A botnet controller (threat source) directs a Distributed Denial-of-Service attack (T-01) against the public Web Server (HW-01), exploiting overly permissive and misconfigured rules on the FortiGate 100F firewall (V-03), causing a loss of availability of the public website (SV-01) and disrupting customer-facing operations.

Attack narrative. The attack typically begins with reconnaissance of the public IP space to confirm the Web Server is reachable and to fingerprint its capacity. The adversary then commands a botnet to direct a volumetric or application-layer flood at the server. Because the FortiGate rule base is permissive and lacks rate-limiting, the malicious traffic is not distinguished from legitimate requests and is forwarded to the server. The server's connection and resource limits are exhausted, legitimate customers are denied service, and the outage persists until traffic is filtered or capacity is added.

Business consequences. A successful DDoS would render the public website and any dependent online services unavailable for the duration of the attack, directly interrupting customer transactions and self-service. Beyond immediate revenue loss, prolonged or repeated outages erode customer confidence and brand reputation and may breach availability commitments in customer or partner service-level agreements.

RS-02: Phishing Credential Theft (Confidentiality)

Scenario ID	RS-02
Asset	Employee Laptops / Desktop PCs — HW-09/12/14
Threat Event	T-02 — Phishing / Spear-Phishing [Source: Social Engineering]
Vulnerability	V-09 — Low Cybersecurity Awareness [Category: Human / Training]
Affected Service	SV-04 Email Service; internal systems
CIA Impact	Confidentiality
Existing Controls & Gaps	Periodic awareness training (inconsistent coverage); basic email filtering assumed; MFA not enforced.
Risk Statement	A phishing attacker (threat source) sends a convincing fraudulent email (T-02) to staff operating laptops and desktop PCs (HW-09/12/14), exploiting low cybersecurity awareness among employees (V-09), causing disclosure of credentials and a loss of confidentiality of internal systems and data.

Attack narrative. The adversary crafts a convincing email — often impersonating a known brand, supplier or internal department — and sends it to one or more employees. Lacking the awareness to detect the lure, a recipient clicks the link and submits credentials to a spoofed portal or opens a malicious attachment. The harvested credentials are then used to authenticate internal services; with no MFA to block reuse, the attacker gains a legitimate-looking foothold from which to access data or move laterally.

Business consequences. Successful phishing typically results in account compromise that serves as a beachhead for wider intrusion, including data theft, fraud or ransomware staging. Because the harvested access can reach systems holding personal and financial data, the organization faces potential regulatory notification obligations under PDPA and GDPR, alongside investigation, remediation and reputational costs.

RS-03: Ransomware on Storage Server (Availability / Integrity)

Scenario ID	RS-03
Asset	Storage Server (DMZ) — HW-02
Threat Event	T-03 — Ransomware [Source: Malicious Outsiders]
Vulnerability	V-04 — Lack of Encryption at Rest [Category: Technical]
Affected Service	SV-02 File Storage & Backup Service
CIA Impact	Availability / Integrity
Existing Controls & Gaps	Ad-hoc backups present; no immutable/tested backups; EDR and incident response not evidenced.
Risk Statement	A ransomware operator (threat source) deploys ransomware (T-03) that propagates to the Storage Server (HW-02), exploiting the absence of encryption at rest and weak data-protection controls (V-04), causing encryption of corporate data and backups and a loss of availability and integrity of the storage service (SV-02).

Attack narrative. Initial access is usually obtained through a phishing email or exposed service, after which the attacker escalates privileges and enumerates network shares. The ransomware payload is deployed to the Storage Server and propagates across reachable systems, encrypting files. Because data is unencrypted at rest and backups are neither immutable nor tested, the attacker can also corrupt or encrypt the backups, removing the organization's ability to recover and maximizing pressure to pay the ransom.

Business consequences. A ransomware event affecting the storage server and backups would halt operations dependent on that data and could render information permanently unrecoverable. The organization would face ransom demands, extended downtime, recovery and forensic costs, and potential breach-notification obligations where personal data is exfiltrated prior to encryption — collectively a business-critical impact.

RS-04: SQL Injection on Application Server (Confidentiality / Integrity)

Scenario ID	RS-04
Asset	Application Server (DMZ) — HW-03
Threat Event	T-04 — SQL Injection [Source: Malicious Outsiders]
Vulnerability	V-06 — Improper Input Validation [Category: Technical]
Affected Service	SV-03 Business Application Service
CIA Impact	Confidentiality / Integrity
Existing Controls & Gaps	Network perimeter controls only; no WAF, secure-coding standard or input-validation assurance evidenced.
Risk Statement	An external attacker (threat source) submits crafted SQL through a web form (T-04) processed by the Application Server (HW-03), exploiting improper input validation (V-06), causing unauthorized extraction and alteration of back-end customer and business data — a loss of confidentiality and integrity of the application service (SV-03).

Attack narrative. The attacker probes the public application for input fields that reach the database. On identifying a field that is not properly validated, they submit crafted SQL that the Application Server executes against its database. Through successive injected queries the attacker enumerates tables, extracts restricted customer and financial records, and may alter or delete data without valid credentials, because the application trusts unsensitized input.

Business consequences. Exploitation would expose restricted customer PII and financial records and permit silent tampering with stored data, undermining both confidentiality and integrity. The consequences include regulatory penalties, contractual liability, loss of customer trust, and the cost of forensic investigation and data-integrity restoration.

RS-05: Wireless Man-in-the-Middle (Confidentiality)

Scenario ID	RS-05
-------------	-------



Asset	Wi-Fi Router / Wireless Clients — HW-06
Threat Event	T-05 — Man-in-the-Middle (MitM) [Source: Malicious Outsiders]
Vulnerability	V-02 — Weak or Default Wi-Fi Credentials [Category: Configuration]
Affected Service	NW-03 Wireless Network
CIA Impact	Confidentiality
Existing Controls & Gaps	Wireless encryption configurable on the RV340W; strong/enterprise authentication and key rotation not confirmed.
Risk Statement	An attacker within wireless range (threat source) intercepts traffic via a Man-in-the-Middle attack (T-05) on the Cisco RV340W wireless network (HW-06), exploiting weak or default Wi-Fi credentials (V-02), causing interception of employee credentials and sensitive data — a loss of confidentiality on the wireless network (NW-03).

Attack narrative. Positioned within wireless range, the attacker exploits the weak or default Wi-Fi credentials to associate with the corporate network or to stand up a rogue access point. They then interpose themselves between client devices and the gateway, capturing or relaying traffic. Credentials, session tokens and sensitive data transmitted by employee devices are intercepted and may be replayed to access further systems.

Business consequences. Interception of wireless traffic would expose employee credentials and any sensitive data transmitted over the affected segment, potentially enabling onward access to internal systems. The impact is contained by wireless-adjacent assets but can act as an entry point to more significant compromise if intercepted credentials are reused.

RS-06: Malware Propagation on Internal LAN (Integrity / Availability)

Scenario ID	RS-06
Asset	Internal Switches / Internal LAN — HW-07
Threat Event	T-08 — Malware / Trojan [Source: Unintentional Insiders]
Vulnerability	V-08 — Lack of Network Segmentation [Category: Configuration]
Affected Service	NW-01 Internal LAN
CIA Impact	Integrity / Availability
Existing Controls & Gaps	Endpoint OS protections present; VLAN segmentation, NAC and removable-media controls not evidenced.
Risk Statement	A user unintentionally introduces a Trojan via removable media or a malicious download (T-08) onto the internal LAN (HW-07), exploiting the lack of VLAN segmentation on the Catalyst switches (V-08), causing lateral propagation of malware to critical servers — a loss of integrity and availability across the internal network (NW-01).

Attack narrative. A user unintentionally executes a Trojan delivered via a malicious download or infected removable device. The malware establishes persistence at the endpoint and begins scanning the local network. Because the internal LAN is not segmented, the malware moves laterally across the flat network to reach critical servers, amplifying a single-host infection into an estate-wide integrity and availability incident.

Business consequences. Unchecked malware propagation across the flat internal network could disrupt or corrupt multiple systems simultaneously, degrading productivity and data integrity across departments. Remediation would require coordinated containment, eradication and recovery effort proportional to the spread, with associated downtime and operational cost.

RS-07: VPN Credential Theft (Confidentiality)

Scenario ID	RS-07
Asset	VPN / Remote Access (Remote Employees) — NW-04
Threat Event	T-12 — VPN Credential Theft [Source: Malicious Outsiders]
Vulnerability	V-07 — Weak Password Policy [Category: Configuration / Process]
Affected Service	SV-06 VPN Remote-Access Service
CIA Impact	Confidentiality
Existing Controls & Gaps	VPN provides encrypted transport; MFA, account lockout and session monitoring not enforced.
Risk Statement	An attacker (threat source) obtains VPN credentials through brute-force or credential-stuffing (T-12) against the remote-access service (NW-04), exploiting the absence of a strong password policy and MFA (V-07), causing full impersonated remote access to internal systems — a loss of confidentiality of the VPN service (SV-06).

Attack narrative. The attacker acquires candidate credentials through phishing, prior breaches or brute-force, then attempts them against the VPN endpoint. With no MFA and no lockout policy, repeated attempts eventually succeed or a valid credential is reused. The attacker establishes a VPN session that grants trusted, internal-equivalent network access, from which they can reach internal systems and data while appearing to be a legitimate remote employee.

Business consequences. Compromise of the VPN grants trusted, internal-equivalent access, from which an attacker can reach a broad range of systems and data while appearing legitimate. The potential consequence is an organization-wide breach affecting confidentiality across multiple data categories, with attendant regulatory, financial and reputational impact.

RS-08: Firewall Zero-Day Exploit (Confidentiality / Availability)

Scenario ID	RS-08
Asset	Firewall (FortiGate 100F) — HW-04
Threat Event	T-10 — Zero-Day Exploit [Source: Malicious Outsiders / Technological Failure]
Vulnerability	V-03 — Misconfigured Firewall Rules [Category: Configuration]
Affected Service	NW-06 Security Perimeter Boundary
CIA Impact	Confidentiality / Availability
Existing Controls & Gaps	FortiGate provides perimeter control when current; patch cadence, threat-intel subscription and management-plane segmentation uncertain.
Risk Statement	A sophisticated attacker (threat source) exploits an unpatched zero-day vulnerability (T-10) in the FortiGate 100F (HW-04), compounded by permissive misconfigured rules (V-03), causing unrestricted access across internal segments — a loss of confidentiality and availability at the security perimeter (NW-06).

Attack narrative. A capable adversary identifies an unpatched zero-day vulnerability in the firewall's operating system and develops or acquires an exploit. They target the Internet-facing management or data plan of the FortiGate, gaining control of the appliance before a vendor patch is available. Combined with permissive rules, this control of the principal boundary device allows the attacker to traverse internal segments largely unimpeded.

Business consequences. Compromise of the perimeter firewall would neutralize the organization's principal boundary control, exposing internal segments to largely unrestricted access. The consequence is potentially catastrophic, enabling widespread data access and disruption before detection, though the likelihood of a specific zero-day is constrained.

RS-09: Insider Interception of VoIP (Confidentiality)

Scenario ID	RS-09
Asset	IP Phone / Internal Communications — HW-13
Threat Event	T-06 — Insider Threat [Source: Malicious Insiders]
Vulnerability	V-08 — Lack of Network Segmentation [Category: Configuration]



Affected Service	SV-07 VoIP / IP Telephony Service
CIA Impact	Confidentiality
Existing Controls & Gaps	Logical/physical DMZ separation exists; voice/data VLAN segregation and access logging limited.
Risk Statement	A disgruntled employee (threat source) abuses internal access (T-06) to the unsegmented VoIP infrastructure (HW-13), exploiting the lack of network segmentation (V-08), causing interception of sensitive voice communications — a loss of confidentiality of the telephony service (SV-07).

Attack narrative. A disgruntled employee with legitimate internal access uses the unsegmented network to reach the VoIP infrastructure. Exploiting the lack of segregation between voice and data, they tap call traffic or access telephony management to monitor or record sensitive conversations. Because access logging is limited, the activity can continue undetected for an extended period.

Business consequences. Interception of internal voice communications could expose confidential discussions, including commercially or personally sensitive matters. The impact is moderate and generally recoverable, but the covert nature of insider interception means exposure may continue undetected, compounding the confidentiality consequence over time.

RS-10: Router Brute-Force Compromise (Confidentiality / Availability)

Scenario ID	RS-10
Asset	Router (Cisco ISR 4321) — HW-05
Threat Event	T-07 — Brute Force / Password Attack [Source: Malicious Outsiders]
Vulnerability	V-07 — Weak Password Policy [Category: Configuration / Process]
Affected Service	NW-01 / NW-05 Routing & Connectivity
CIA Impact	Confidentiality / Availability
Existing Controls & Gaps	Router enforces routing; account lockout, MFA and out-of-band management not in place.
Risk Statement	An attacker (threat source) launches an automated brute-force attack (T-07) against the router management interface (HW-05), exploiting the weak password policy and absence of lockout/MFA (V-07), causing administrative compromise that allows traffic rerouting and interception — a loss of confidentiality and availability of network routing (NW-01/NW-05).

Attack narrative. The attacker locates the router's management interface, which is reachable from general network segments, and launches an automated brute-force attack against it. With no account-lockout policy or MFA, the tool eventually guesses valid administrative credentials. Holding administrative control of the core router, the attacker can reroute or mirror traffic, disrupt connectivity, and intercept communications across the network.

Business consequences. Administrative compromise of the core router would allow an attacker to reroute, mirror or disrupt network traffic, threatening both confidentiality and availability across the organization. As a single point of failure, the router's compromise represents an infrastructure-level consequence affecting all dependent services.

RS-11: Social Engineering of Staff (Confidentiality)

Scenario ID	RS-11
Asset	Employee Laptops / Mobile Devices — HW-09/11
Threat Event	T-11 — Social Engineering [Source: Social Engineering]
Vulnerability	V-09 — Low Cybersecurity Awareness [Category: Human / Training]
Affected Service	Endpoints; internal systems
CIA Impact	Confidentiality
Existing Controls & Gaps	Awareness training partial; identity-verification/call-back procedures and endpoint install restrictions not evidenced.
Risk Statement	An attacker impersonating IT support (threat source) manipulates an employee (T-11) into disclosing a password or installing remote-access software on a laptop or phone (HW-09/11), exploiting low cybersecurity awareness (V-09), causing unauthorized access — a loss of confidentiality of endpoints and connected systems.

Attack narrative. The attacker telephones or messages an employee while impersonating IT support, citing a plausible pretext such as an urgent account issue. Lacking trained verification behaviors, the employee discloses a password or is guided into installing remote-access software on their device. The attacker then uses this access to reach the employee's accounts and connected systems, having bypassed technical defenses entirely through manipulation.

Business consequences. Successful social engineering yields unauthorized access to an individual's accounts and device, which can be leveraged to reach connected systems and data. While the immediate impact is contained to the targeted user, access frequently serves as a pivot toward more significant compromise, making the consequence material despite its localized origin.

RS-12: Printer Document Interception (Confidentiality)

Scenario ID	RS-12
Asset	Printer (HP LaserJet Pro M404dn) — HW-15
Threat Event	T-05 — Man-in-the-Middle (MitM) [Source: Malicious Outsiders / Insiders]
Vulnerability	V-12 — Unsecured Network Printing Services [Category: Configuration]
Affected Service	SV-08 Network Printing Service
CIA Impact	Confidentiality
Existing Controls & Gaps	Printer on internal network; management-interface authentication, secure printing and VLAN isolation not in place.
Risk Statement	An internal network attacker (threat source) accesses the unsecured printer management interface (T-05) on the HP LaserJet Pro M404dn (HW-15), exploiting the absence of authentication on network printing services (V-12), causing interception of sensitive printed documents — a loss of confidentiality of the printing service (SV-08).

Attack narrative. An attacker with internal network access discovers the printer's management interface, which requires no authentication. They access stored or spooled print jobs or reconfigure the device to forward copies of documents. Sensitive documents passing through the shared printer may be intercepted without the knowledge of the users who submitted them; however, exposure is limited to the documents that happen to transit this single shared device.

Business consequences. Interception of printed documents could expose limited internal information without the awareness of the individuals who printed them. The exposure is localized to a single shared device, is easily contained once detected, and involves only the subset of documents transiting that printer — a minor, recoverable confidentiality consequence.

B.7 Risk Identification Summary

The twelve identified scenarios are consolidated below as the complete input to the Risk Analysis phase.

ID	Asset	Threat	Vulnerability	CIA Impact
RS-01	Web Server (DMZ)	DDoS Attack	Misconfigured firewall rules	Availability
RS-02	Employee Endpoints	Phishing / Spear-Phishing	Low security awareness; no MFA	Confidentiality
RS-03	Storage Server (DMZ)	Ransomware	No encryption at rest; weak backups	Availability / Integrity
RS-04	Application Server (DMZ)	SQL Injection	Improper input validation	Confidentiality / Integrity
RS-05	Wi-Fi Router / Clients	Man-in-the-Middle	Weak / default Wi-Fi credentials	Confidentiality
RS-06	Internal Switches / LAN	Malware / Trojan	No network segmentation	Integrity / Availability
RS-07	VPN / Remote Access	VPN Credential Theft	Weak password policy; no MFA	Confidentiality
RS-08	Firewall (FortiGate 100F)	Zero-Day Exploit	Patch latency; misconfigured rules	Confidentiality / Availability
RS-09	IP Phone / Telephony	Insider Threat	No voice/data segmentation; limited logging	Confidentiality
RS-10	Router (Cisco ISR 4321)	Brute Force / Password Attack	Weak password policy; no lockout/MFA	Confidentiality / Availability
RS-11	Employee Endpoints / Mobile	Social Engineering	Low security awareness; no verification procedures	Confidentiality
RS-12	Printer (HP LaserJet)	Man-in-the-Middle	Unsecured network printing services	Confidentiality

B.8 CIA Impact Mapping

Mapping each scenario to the CIA dimension(s) it affects confirms balanced coverage across confidentiality, integrity and availability and informs the impact judgments in Section C. A check mark (✓) denotes a primary affected dimension.

ID	Asset	Confidentiality	Integrity	Availability
RS-01	Web Server (DMZ)	—	—	✓
RS-02	Employee Endpoints	✓	—	—
RS-03	Storage Server (DMZ)	—	✓	✓
RS-04	Application Server (DMZ)	✓	✓	—
RS-05	Wi-Fi Router / Clients	✓	—	—
RS-06	Internal Switches / LAN	—	✓	✓
RS-07	VPN / Remote Access	✓	—	—

ID	Asset	Confidentiality	Integrity	Availability
RS-08	Firewall (FortiGate 100F)	✓	—	✓
RS-09	IP Phone / Telephony	✓	—	—
RS-10	Router (Cisco ISR 4321)	✓	—	✓
RS-11	Employee Endpoints / Mobile	✓	—	—
RS-12	Printer (HP LaserJet)	✓	—	—

Confidentiality is the most frequently affected dimension, reflecting the prominence of credential theft, interception and data-exposure threats in AL-ITTIHAD's profile, while integrity and availability concentrate around the ransomware, malware and infrastructure scenarios. This concludes Risk Identification; Section C analyses each scenario to determine its likelihood, impact and resulting risk level.

Section C: Risk Analysis

The Risk Analysis phase (Phase 3 of ISO/IEC 27005) assigns each identified scenario a likelihood and an impact rating, computes its risk score, and translates that score into a risk level using the criteria defined in Section A.7. The analysis is semi-quantitative: ratings are evidence-based judgments calibrated to the AL-ITTIHAD likelihood and impact scales rather than precise probabilities. The result is a prioritized view of the organization's twelve risks and the consolidated input to the Risk Register in Section D.

C.1 Analysis Method

Each scenario is rated for Likelihood (1–5) and Impact (1–5); the Risk Score is their product, and the Risk Level follows the classification in Section A.7.3 (Very Low 1–4, Low 5–9, Medium 10–14, High 15–19, Critical 20–25). For each scenario, the analysis records the likelihood rating and its justification, the impact rating and its justification, the resulting score and level, a short commentary explaining the rating, and a note on how existing controls influenced the assessment. The prioritized output supports the evaluation and treatment decisions and the consolidated risk register that follow.

C.2 Detailed Risk Analysis (RS-01 to RS-12)

RS-01 — Web Server (DMZ) / DDoS Attack

Analysis Factor	Assessment
Likelihood Rating	Likely (4)
Likelihood Justification	Public-facing web assets of multinationals are routinely targeted by volumetric and application-layer DDoS campaigns; such events are observed at least once per year across comparable organizations.
Impact Rating	Major (4)
Impact Justification	Sustained unavailability of the public website interrupts customer transactions and damages reputation, with downtime likely exceeding 24 hours and financial impact in the RM 100K–1M band.
Risk Score	$4 \times 4 = 16$
Risk Level	High

Commentary. This risk scores 16 (High): a Likely threat against a Major-impact, Internet-facing asset. The existing reliance on a single perimeter firewall without upstream DDoS protection or rate-limiting means the likelihood is driven by exposure rather than by attacker sophistication. Because the Web Server underpins customer-facing revenue, the impact is dominated by availability loss and reputational harm, justifying prompt mitigation.

Influence of existing controls. Existing controls offer only partial mitigation: the perimeter firewall provides basic filtering but there is no upstream DDoS scrubbing, rate-limiting or capacity headroom, and detective monitoring is weak. The likelihood rating therefore reflects largely unmitigated exposure of an Internet-facing asset.

RS-02 — Employee Endpoints / Phishing / Spear-Phishing

Analysis Factor	Assessment
Likelihood Rating	Very Likely (5)
Likelihood Justification	Phishing is the single most frequently observed initial-access vector; with limited and inconsistent awareness coverage, successful lures are expected to occur multiple times per year.
Impact Rating	Major (4)
Impact Justification	Harvested credentials grant attackers a foothold into internal systems, enabling onward access to sensitive customer and employee data — a Major impact with probable regulatory exposure.
Risk Score	$5 \times 4 = 20$
Risk Level	Critical

Commentary. This risk scores 20 (Critical): a Very Likely threat with Major impact. The rating is dominated by the human-factor vulnerability: inconsistent awareness coverage makes successful phishing close to inevitable over an annual horizon, and the consequence (credential compromise leading to internal access) is severe. The absence of enforced MFA removes the compensating control that would otherwise contain a successful lure.

Influence of existing controls. No multi-factor authentication is enforced, and awareness-training coverage is inconsistent, so the compensating controls that would normally blunt phishing are effectively absent. This control gap is the primary reason the likelihood is rated Very Likely.

RS-03 — Storage Server (DMZ) / Ransomware

Analysis Factor	Assessment
Likelihood Rating	Possible (3)
Likelihood Justification	Ransomware targeting file and backup repositories has occurred in similar environments; AL-ITTihad's exposure is moderated by perimeter controls but remains a credible 1–3 year event.
Impact Rating	Critical (5)
Impact Justification	Encryption of primary data and backups would halt operations, trigger potential ransom and recovery costs exceeding RM 1M, and constitute a Critical, possibly unrecoverable, event.
Risk Score	$3 \times 5 = 15$
Risk Level	High

Commentary. This risk scores 15 (High): a Possible threat with Critical impact. Likelihood is tempered by perimeter controls, but the impact is maximal because data is unencrypted at rest and backups are neither immutable nor tested — meaning a single successful intrusion could render both primary and backup data unrecoverable. The impact rating therefore drives the overall level.

Influence of existing controls. Backups exist but are neither immutable nor regularly tested, and there is no confirmed EDR or formal incident-response capability. These corrective-control gaps drive the Critical impact, since recovery from a successful event is not assured.

RS-04 — Application Server (DMZ) / SQL Injection

Analysis Factor	Assessment
Likelihood Rating	Possible (3)
Likelihood Justification	Injection remains among the most common web-application attack classes; exploitation is possible where input validation is weak and has occurred in comparable deployments.
Impact Rating	Critical (5)
Impact Justification	Direct database compromise exposes restricted customer PII and financial records and permits data tampering — a Critical impact with significant regulatory and contractual consequences.
Risk Score	$3 \times 5 = 15$
Risk Level	High

Commentary. This risk scores 15 (High): a Possible threat with Critical impact. Injection likelihood is governed by the application's weak input validation, while the impact is severe because the Application Server fronts restricted customer PII and financial records. The combination of a common attack class with a high-value data store warrants priority treatment.

Influence of existing controls. Application-layer controls (input validation, WAF, secure-coding review) were not evidenced. The absence of these preventive controls keeps the likelihood at Possible and leaves the high-value data store directly exposed.

RS-05 — Wi-Fi Router / Clients / Man-in-the-Middle

Analysis Factor	Assessment
Likelihood Rating	Possible (3)
Likelihood Justification	Wireless interception requires local proximity and is constrained, but default or weak credentials make opportunistic MitM a realistic periodic occurrence.
Impact Rating	Major (4)
Impact Justification	Captured session data and credentials can expose sensitive employee and corporate information — a Major confidentiality impact, though contained to wireless-adjacent assets.
Risk Score	$3 \times 4 = 12$
Risk Level	Medium

Commentary. This risk scores 12 (Medium): a Possible threat with Major impact. Likelihood is constrained by the need for physical proximity to the wireless network, but weak or default credentials make opportunistic interception realistic. The impact reflects potential exposure of employee credentials and corporate data traversing the wireless segment.

Influence of existing controls. Wireless security depends on credential and protocol configuration; default or weak settings and the absence of enterprise authentication mean the enabling weakness is largely uncontrolled, though proximity requirements limit likelihood.

RS-06 — Internal Switches / LAN / Malware / Trojan

Analysis Factor	Assessment
Likelihood Rating	Possible (3)
Likelihood Justification	Endpoint malware introduction is a recurring event; the flat network design materially raises the chance of lateral spread once a single host is infected.
Impact Rating	Major (4)
Impact Justification	Unsegmented spread can reach multiple critical systems, causing Major operational disruption and remediation effort across the estate.
Risk Score	$3 \times 4 = 12$
Risk Level	Medium

Commentary. This risk scores 12 (Medium): a Possible threat with Major impact. Endpoint malware introduction is recurrent, but the Major impact is a function of the flat network design — without VLAN segmentation, a single infected host can propagate to critical servers. The vulnerability therefore amplifies an otherwise routine threat.

Influence of existing controls. The flat network design and absence of confirmed EDR and removable-media controls mean a single infection can spread unchecked. Containment controls (segmentation) are the missing element that would reduce the impact dimension.

RS-07 — VPN / Remote Access / VPN Credential Theft

Analysis Factor	Assessment
Likelihood Rating	Likely (4)
Likelihood Justification	Credential-based attacks against remote access are highly prevalent; without MFA and lockout, successful compromise is likely on at least an annual basis.
Impact Rating	Critical (5)
Impact Justification	A valid VPN session grants trusted network access equivalent to an internal user, enabling broad data access and a Critical organization-wide exposure.
Risk Score	$4 \times 5 = 20$
Risk Level	Critical

Commentary. This risk scores 20 (Critical): a Likely threat with Critical impact. The rating reflects that VPN access grants trusted, internal-equivalent network presence, so any credential compromise is organization-wide in consequence. The absence of MFA and a strong password policy make successful credential attacks likely, compounding an already maximal impact.

Influence of existing controls. The decisive missing control is MFA; with only single-factor credentials and no lockout, the remote-access pathway is highly exposed. Session monitoring is also weak, delaying detection of misuse.

RS-08 — Firewall (FortiGate 100F) / Zero-Day Exploit

Analysis Factor	Assessment
Likelihood Rating	Unlikely (2)
Likelihood Justification	Zero-day exploitation of a specific appliance is comparatively rare and requires advanced capability, but is not implausible for an Internet-facing security device.
Impact Rating	Critical (5)
Impact Justification	Compromise of the perimeter firewall undermines the principal boundary control — a Critical impact enabling wide internal access.
Risk Score	$2 \times 5 = 10$
Risk Level	Medium

Commentary. This risk scores 10 (Medium): an Unlikely threat with Critical impact. Zero-day exploitation of the specific appliance requires advanced capability, keeping likelihood low, but the impact is Critical because the firewall is the principal perimeter control. The score sits at the Medium/High boundary and is sensitive to patch latency.

Influence of existing controls. Patch cadence and vendor threat-intelligence subscription were not evidenced, and management-plane segmentation is uncertain. While the appliance provides strong perimeter control when current, latency in patching governs the residual exposure.

RS-09 — IP Phone / Telephony / Insider Threat

Analysis Factor	Assessment
Likelihood Rating	Unlikely (2)
Likelihood Justification	Malicious insider exploitation of telephony is unlikely but possible given internal access and weak segmentation.
Impact Rating	Moderate (3)
Impact Justification	Interception of internal calls causes a Moderate confidentiality impact, generally limited in scope and recoverable.
Risk Score	$2 \times 3 = 6$
Risk Level	Low

Commentary. This risk scores 6 (Low): an Unlikely threat with Moderate impact. Insider abuse of the telephony segment requires both motive and access, and the consequence — interception of internal calls — is moderate and generally recoverable. The score falls within appetite, making acceptance with monitoring a viable option.

Influence of existing controls. Voice and data share network segments and access logging is limited, so insider misuse would be difficult to detect. However, the requirement for legitimate internal access and the moderate impact keep this risk within appetite.

RS-10 — Router (Cisco ISR 4321) / Brute Force / Password Attack

Analysis Factor	Assessment
Likelihood Rating	Possible (3)
Likelihood Justification	Brute-force against exposed management interfaces is common where lockout and MFA are absent; a credible periodic occurrence.
Impact Rating	Critical (5)
Impact Justification	Administrative control of the core router permits traffic manipulation and full interception — a Critical infrastructure-level impact.
Risk Score	$3 \times 5 = 15$
Risk Level	High

Commentary. This risk scores 15 (High): a Possible threat with Critical impact. Brute-force against an exposed management interface is credible where lockout and MFA are absent, and administrative control of the core router is a Critical, infrastructure-level consequence enabling traffic manipulation. The impact dimension drives the rating.

Influence of existing controls. Management access lacks lockout and MFA and may be reachable from general network segments. Restricting and authenticating management access is the key absent control that currently elevates likelihood.

RS-11 — Employee Endpoints / Mobile / Social Engineering

Analysis Factor	Assessment
Likelihood Rating	Likely (4)
Likelihood Justification	Pretexting and impersonation are frequently attempted and often succeed without trained verification behaviours; likely on at least an annual basis.
Impact Rating	Moderate (3)
Impact Justification	Compromise of an individual endpoint and its access yields a Moderate impact — contained relative to server-side breaches but a credible pivot point.
Risk Score	$4 \times 3 = 12$
Risk Level	Medium

Commentary. This risk scores 12 (Medium): a Likely threat with Moderate impact. Impersonation succeeds frequently in absent trained verification behaviors, but the impact is contained to an individual endpoint and its access rather than a server-side breach. Human-factor vulnerability sustains the likelihood.

Influence of existing controls. As with RS-02, the absence of trained verification behaviors and enforced MFA leaves employees exposed to manipulation; behavioral controls are partial at best, sustaining the Likely rating.

RS-12 — Printer (HP LaserJet) / Man-in-the-Middle

Analysis Factor	Assessment
Likelihood Rating	Unlikely (2)
Likelihood Justification	Printer-based interception is unlikely and opportunistic, requiring internal network access to an often-overlooked device.
Impact Rating	Minor (2)
Impact Justification	Exposure is limited to documents that transit a single shared device; the incident is localized, easily contained and involves only limited internal data — a Minor confidentiality impact.
Risk Score	$2 \times 2 = 4$
Risk Level	Very Low

Commentary. This risk scores 4 (Very Low): an Unlikely threat with Minor impact. Printer-based interception is opportunistic and requires internal access to an often-overlooked device, and the exposure is limited to the documents that happen to transit a single shared printer. The score falls well within appetite, making acceptance with periodic monitoring appropriate.

Influence of existing controls. The printer is an often-overlooked device with an unauthenticated management interface and no confirmed network isolation; however, the Minor impact and the internal-access requirement keep the risk within appetite, so periodic monitoring and basic hardening are sufficient.

C.3 Consolidated Risk Analysis Results

The table below consolidates the analysis. Risks are listed by scenario ID with their likelihood, impact, score and color-coded level, providing the prioritized basis for evaluation and treatment.

ID	Asset	Threat	L	I	Score	Risk Level
RS-01	Web Server (DMZ)	DDoS Attack	4	4	16	High
RS-02	Employee Endpoints	Phishing / Spear-Phishing	5	4	20	Critical
RS-03	Storage Server (DMZ)	Ransomware	3	5	15	High
RS-04	Application Server (DMZ)	SQL Injection	3	5	15	High
RS-05	Wi-Fi Router / Clients	Man-in-the-Middle	3	4	12	Medium
RS-06	Internal Switches / LAN	Malware / Trojan	3	4	12	Medium
RS-07	VPN / Remote Access	VPN Credential Theft	4	5	20	Critical
RS-08	Firewall (FortiGate 100F)	Zero-Day Exploit	2	5	10	Medium
RS-09	IP Phone / Telephony	Insider Threat	2	3	6	Low
RS-10	Router (Cisco ISR 4321)	Brute Force / Password Attack	3	5	15	High
RS-11	Employee Endpoints / Mobile	Social Engineering	4	3	12	Medium
RS-12	Printer (HP LaserJet)	Man-in-the-Middle	2	2	4	Very Low

Risk distribution. Across the twelve scenarios the portfolio now spans all five risk levels: 2 Critical (RS-02, RS-07), 4 High (RS-01, RS-03, RS-04, RS-10), 4 Medium (RS-05, RS-06, RS-08, RS-11), 1 Low (RS-09) and 1 Very Low (RS-12). The two Critical and four High risks together account for half of the portfolio and concentrate around Internet-facing services, remote access and core infrastructure, where exposure and consequence are both greatest. The Medium, Low and Very Low risks, while not demanding immediate action, remain subject to monitoring and periodic review.

C.4 Risk Matrix (5 × 5 Likelihood × Impact)

The matrix plots every scenario by its likelihood and impact. Cell color denotes the resulting risk level; scenario IDs are positioned in the cell corresponding to their rating, giving management an at-a-glance heat-map of where risk concentrates.

Likelihood ↓ / Impact →	1 Negligible	2 Minor	3 Moderate	4 Major	5 Critical
5 Very Likely	5	10	15	20 RS-02	25
4 Likely	4	8	12 RS-11	16 RS-01	20 RS-07
3 Possible	3	6	9	12 RS-05, RS-06	15 RS-03, RS-04, RS-10
2 Unlikely	2	4 RS-12	6 RS-09	8	10 RS-08
1 Rare	1	2	3	4	5

Legend: Critical (20–25) High (15–19) Medium (10–14) Low (5–9) Very Low (1–4).

C.5 Key Observations

Several patterns emerge from the analysis. First, the highest risks cluster on the boundary between the organization and the outside world — the public Web Server (RS-01), the VPN remote-access service (RS-07) and the employee-targeted phishing vector (RS-02) confirming that AL-ITTIHAD's exposure is concentrated where its attack surface meets the Internet and its workforce. Second, the most severe impacts arise where a single compromise can cascade ransomware against unprotected backups (RS-03), injection against a high-value data store (RS-04), and administrative compromise of the core router (RS-10). Third, the recurring root causes are a small number of absent controls — multi-factor authentication, network segmentation, immutable backups and consistent awareness training — each of which appears across multiple scenarios, indicating that a few targeted investments would reduce several risks simultaneously.

The presence of a Very Low risk (RS-12) and a Low risk (RS-09) at the opposite end of the scale confirms that the portfolio is now fully differentiated across all five levels. These lowest-rated scenarios remain valid and are retained, but their scores fall within the organization's risk appetite and are appropriately managed through monitoring rather than active treatment.

C.6 Risk Driver Classification

Classifying each risk by whether its score is driven primarily by likelihood, by impact, or by both in balance clarifies the most effective control emphasis. Likelihood-driven risks call for preventive controls that reduce the chance of occurrence; impact-driven risks call for resilience and containment controls that limit consequence; balanced risks benefit from both.

ID	Asset	L	I	Risk Driver	Control Emphasis
RS-01	Web Server (DMZ)	4	4	Balanced	Prevention + Resilience
RS-02	Employee Endpoints	5	4	Likelihood-driven	Prevention
RS-03	Storage Server (DMZ)	3	5	Impact-driven	Resilience / Containment
RS-04	Application Server (DMZ)	3	5	Impact-driven	Resilience / Containment
RS-05	Wi-Fi Router / Clients	3	4	Impact-driven	Resilience / Containment
RS-06	Internal Switches / LAN	3	4	Impact-driven	Resilience / Containment
RS-07	VPN / Remote Access	4	5	Impact-driven	Resilience / Containment
RS-08	Firewall (FortiGate 100F)	2	5	Impact-driven	Resilience / Containment
RS-09	IP Phone / Telephony	2	3	Impact-driven	Resilience / Containment
RS-10	Router (Cisco ISR 4321)	3	5	Impact-driven	Resilience / Containment
RS-11	Employee Endpoints / Mobile	4	3	Likelihood-driven	Prevention
RS-12	Printer (HP LaserJet)	2	2	Balanced	Prevention + Resilience

The classification shows that most of AL-ITTIHAD's significant risks are impact-driven — their scores reflect the severity of consequence more than the frequency of occurrence — which argues for prioritizing resilience and containment investments such as immutable backups, network segmentation and incident-response capability. The likelihood-driven human-factor risks (RS-02 and RS-11) are best addressed through prevention, principally awareness training and MFA, while the balanced risks (RS-01 and RS-12) warrant a combination of preventive and resilience measures proportional to their level.

C.7 Assumptions & Confidence

The analysis rests on the assumptions documented in Section A.9 and on the honest characterization of existing controls in Section B.5. Where a control's effectiveness could not be verified within scope — for example, the firewall's patch cadence or the existence of EDR — the analysis adopted a conservative position, rating residual exposure on the assumption that the control was partial or absent until evidence confirms otherwise. Ratings reflect expert judgment calibrated to industry experience and the AL-ITTIHAD likelihood and impact scales; they are intended to support prioritization, not to express precise probabilities.

Confidence in the ratings is highest for the externally facing, well-understood scenarios (RS-01, RS-02, RS-07) and moderate for those dependent on unverified control states (RS-08 firewall patching, RS-03 backup integrity), which should be revisited once validation evidence is gathered. The scenario closest to a classification boundary is RS-08 at the Medium/High threshold; a confirmed lapse in patch management would move it into the High band and should be monitored accordingly. These analyzed results from the direct input to risk evaluation and risk treatment, and are consolidated for ongoing tracking in the Risk Register that follows in Section D.



C.8 Consolidated Risk Register

The Consolidated Risk Register below provides a single, centralized reference point summarizing all twelve risk scenarios identified and analyzed in this report. It draws together the asset inventory (Section A), the threats, vulnerabilities and risk scenarios (Section B) and the analyzed likelihood, impact, scores and levels (Section C) into one authoritative table, ensuring consistency across the Risk Analysis, Risk Treatment, control-mapping and risk-acceptance activities. All values are reproduced unchanged from the report; risk owners are expressed as role titles and status reflect each risk's level.

Risk ID	Asset ID	Asset	Threat	Vulnerability	Risk Scenario	Likelihood	Impact	Risk Score	Risk Level	Risk Owner	Status
RS-01	HW-01	Web Server (DMZ)	T-01 DDoS Attack	V-03 Misconfigured Firewall Rules	DDoS flooding of the public Web Server, exploiting misconfigured firewall rules, causes a loss of availability of customer-facing services.	Likely (4)	Major (4)	16	High	CISO	Pending Treatment
RS-02	HW-09/12/14	Employee Laptops / Desktop PCs	T-02 Phishing / Spear-Phishing	V-09 Low Cybersecurity Awareness	A phishing email exploits low staff awareness on employee endpoints, leading to credential disclosure and a loss of confidentiality of internal systems.	Very Likely (5)	Major (4)	20	Critical	CISO / IT Security Team	Pending Treatment
RS-03	HW-02	Storage Server (DMZ)	T-03 Ransomware	V-04 Lack of Encryption at Rest	Ransomware reaches the Storage Server, exploiting the lack of encryption at rest and weak backups, encrypting corporate data and backups (loss of availability/integrity).	Possible (3)	Critical (5)	15	High	IT Infrastructure Team	Pending Treatment
RS-04	HW-03	Application Server (DMZ)	T-04 SQL Injection	V-06 Improper Input Validation	Crafted SQL submitted to the Application Server exploits improper input validation, exposing and altering customer and financial data (loss of confidentiality/integrity).	Possible (3)	Critical (5)	15	High	Database Administrator	Pending Treatment
RS-05	HW-06	Wi-Fi Router / Wireless Clients	T-05 Man-in-the-Middle (MitM)	V-02 Weak or Default Wi-Fi Credentials	A man-in-the-middle attack on the wireless network exploits weak or default Wi-Fi credentials, intercepting employee credentials and data (loss of confidentiality).	Possible (3)	Major (4)	12	Medium	Network Administrator	Under Review
RS-06	HW-07	Internal Switches / Internal LAN	T-08 Malware / Trojan	V-08 Lack of Network Segmentation	A Trojan introduced to the internal LAN exploits the lack of network segmentation, propagating laterally to critical servers (loss of integrity/availability).	Possible (3)	Major (4)	12	Medium	Network Administrator	Under Review
RS-07	NW-04	VPN / Remote Access (Remote Employees)	T-12 VPN Credential Theft	V-07 Weak Password Policy	VPN credential theft against the remote-access service exploits the weak password policy and absent MFA, granting impersonated internal access (loss of confidentiality).	Likely (4)	Critical (5)	20	Critical	Security Operations Team	Pending Treatment
RS-08	HW-04	Firewall	T-10 Zero-Day	V-03	A zero-day exploit against the FortiGate	Unlikely (2)	Critical	10	Medium	IT Security	Under

Risk ID	Asset ID	Asset	Threat	Vulnerability	Risk Scenario	Likelihood	Impact	Risk Score	Risk Level	Risk Owner	Status
		(FortiGate 100F)	Exploit	Misconfigured Firewall Rules	firewall, compounded by misconfigured rules, yields unrestricted access across internal segments (loss of confidentiality/availability).		(5)			Team	Review
RS-09	HW-13	IP Phone / Internal Communications	T-06 Insider Threat	V-08 Lack of Network Segmentation	An insider abuses internal access to the unsegmented VoIP infrastructure, exploiting the lack of segmentation to intercept voice communications (loss of confidentiality).	Unlikely (2)	Moderate (3)	6	Low	IT Infrastructure Team	Accepted for Monitoring
RS-10	HW-05	Router (Cisco ISR 4321)	T-07 Brute Force / Password Attack	V-07 Weak Password Policy	A brute-force attack on the router management interface exploits the weak password policy and absent lockout/MFA, enabling traffic rerouting and interception (loss of confidentiality/availability).	Possible (3)	Critical (5)	15	High	IT Infrastructure Manager	Pending Treatment
RS-11	HW-09/11	Employee Laptops / Mobile Devices	T-11 Social Engineering	V-09 Low Cybersecurity Awareness	Social engineering by an attacker impersonating IT support exploits low awareness, obtaining credentials or remote access on employee endpoints (loss of confidentiality).	Likely (4)	Moderate (3)	12	Medium	IT Security Team	Under Review
RS-12	HW-15	Printer (HP LaserJet Pro M404dn)	T-05 Man-in-the-Middle (MitM)	V-12 Unsecured Network Printing Services	Access to the unsecured printer management interface exploits unsecured network printing services, intercepting sensitive printed documents (loss of confidentiality).	Unlikely (2)	Minor (2)	4	Very Low	System Administrator	Accepted for Monitoring

Legend (Risk Level): Critical (20–25) High (15–19) Medium (10–14) Low (5–9) Very Low (1–4). Risk Score = Likelihood × Impact. Status: Pending Treatment (High/Critical), Under Review (Medium), Accepted for Monitoring (Low/Very Low).

Section D: Risk Evaluation

D.1 Risk Evaluation Introduction

Risk Evaluation is the fourth phase of the ISO/IEC 27005 risk management process and follows directly from the Risk Analysis presented in Section C. Whereas Risk Analysis determined the likelihood, impact, score and level of each identified scenario, the purpose of Risk Evaluation is to compare those analyzed results against the organization's documented risk acceptance criteria (Section A.8) in order to decide which risks are acceptable as they stand and which require treatment. Risk Evaluation does not recalculate or alter the analyzed values; it interprets them in the light of AL-ITTIHAD's risk appetite.

Using the likelihood and impact values, risk scores and risk levels already established in the report, each scenario is assigned an evaluation decision — Acceptable, Tolerable or Unacceptable — together with a rationale grounded in its consequences for confidentiality, integrity and availability, and for business operations, service continuity, financial position and reputation. Risks that fall within appetite are accepted and monitored; risks that exceed appetite are flagged as requiring treatment in the subsequent phase.

The outcome of this phase is a prioritized, decision-ready view of the organization's risk portfolio. By ranking risks according to severity and organizational impact, Risk Evaluation determines the order in which exposures should be addressed and provides the objective basis on which management directs resources toward the most significant risks first. This prioritization is the principal input to the risk treatment phase that follows.

D.2 Risk Evaluation Criteria

The evaluation applies the acceptance thresholds defined during Context Establishment (Section A.8), translating each risk level into a formal evaluation status. The status determines whether a risk may be retained as-is, retained subject to mitigation and management oversight, or rejected as exceeding appetite.

Risk Level	Evaluation Status	Description
Critical	Unacceptable	Exceeds risk appetite under all conditions. The combination of likelihood and consequence is intolerable; the risk must be escalated to executive management and treated, transferred or avoided as a matter of priority.
High	Unacceptable	Above the acceptable threshold and may breach service-level, contractual or regulatory obligations. The risk cannot be accepted and must be mitigated promptly with prioritized controls.
Medium	Tolerable	Acceptable only on a conditional basis — that is, subject to cost-justified mitigation and documented management sign-off. The risk is retained under review until reduced or formally accepted.
Low	Acceptable	Within risk appetite. The likelihood and consequences are sufficiently limited so that the risk may be retained with routine monitoring and minor tuning where appropriate.
Very Low	Acceptable	Comfortably within risk appetite. The exposure is negligible and easily contained; no treatment is required beyond periodic monitoring.

Applying these criteria, the two Critical and four High risks are classified Unacceptable and carried forward for treatment; the four medium risks are Tolerable subject to mitigation and oversight; and the single Low and single Very Low risk are Acceptable and managed through monitoring.

D.3 Complete Risk Evaluation Table

The table below evaluates every risk recorded in the Risk Register. Likelihood, impact, risk score and risk level are reproduced unchanged from the Risk Analysis; the evaluation decision, rationale and required action are derived by applying the criteria in D.2. No risk has been omitted, added or re-scored.

Risk ID	Asset	Threat	Likelihood	Impact	Risk Score	Risk Level	Evaluation Decision	Rationale	Required Action
RS-01	Web Server (DMZ)	DDoS Attack	Likely (4)	Major (4)	16	High	Unacceptable	Threatens the availability of the public Web Server (SV-01); a sustained outage halts customer-facing transactions, causing direct revenue loss in the RM 100K–1M band and reputational damage. Availability-driven and above the organization's appetite for Internet-facing services.	Escalate as a high-priority candidate for risk treatment.
RS-02	Employee Endpoints	Phishing / Spear-Phishing	Very Likely (5)	Major (4)	20	Critical	Unacceptable	A Very Likely confidentiality threat; credential compromise opens a path to systems holding customer and employee PII, creating regulatory exposure under PDPA/GDPR alongside fraud and reputational harm. Unacceptable under any condition.	Escalate to top management; forward for immediate treatment.
RS-03	Storage Server (DMZ)	Ransomware	Possible (3)	Critical (5)	15	High	Unacceptable	Endangers the availability and integrity of corporate data and backups; a successful event would halt dependent operations, incur ransom and recovery costs exceeding RM 1M, and may be unrecoverable. Impact-driven and above appetite.	Forward for priority treatment.
RS-04	Application Server (DMZ)	SQL Injection	Possible (3)	Critical (5)	15	High	Unacceptable	Threatens the confidentiality and integrity of restricted customer PII and financial records via the Application Server; exploitation carries regulatory penalties, contractual liability and reputational loss. Above appetite.	Forward for priority treatment.
RS-05	Wi-Fi Router / Clients	Man-in-the-Middle	Possible (3)	Major (4)	12	Medium	Tolerable	A confidentiality risk localized to the wireless segment; interception of credentials and data is materially harmful but contained to wireless-adjacent assets with limited-service disruption. Tolerable only with mitigation and management oversight.	Schedule mitigation within a planned timeframe; management review.
RS-06	Internal Switches / LAN	Malware / Trojan	Possible (3)	Major (4)	12	Medium	Tolerable	An integrity and availability risk amplified by the flat network; a single infection could disrupt multiple systems and degrade data integrity, causing moderate operational and remediation cost. Tolerable	Schedule mitigation within a planned timeframe; management review.

Risk ID	Asset	Threat	Likelihood	Impact	Risk Score	Risk Level	Evaluation Decision	Rationale	Required Action
								conditional on containment improvements.	
RS-07	VPN / Remote Access	VPN Credential Theft	Likely (4)	Critical (5)	20	Critical	Unacceptable	A Likely confidentiality threat granting trusted, internal-equivalent access; compromise enables an organization-wide breach across multiple data categories with severe regulatory, financial and reputational consequences. The maximal-impact, high-likelihood profile makes it unacceptable.	Escalate to top management; forward for immediate treatment.
RS-08	Firewall (FortiGate 100F)	Zero-Day Exploit	Unlikely (2)	Critical (5)	10	Medium	Tolerable	A Critical potential impact (perimeter compromise affecting confidentiality and availability) but an Unlikely occurrence, yielding a medium score at the Medium/High boundary. Tolerable provided patch and monitoring posture is maintained; sensitive to patch latency.	Monitor closely; re-evaluate should patch posture lapse.
RS-09	IP Phone / Telephony	Insider Threat	Unlikely (2)	Moderate (3)	6	Low	Acceptable	A confidentiality risk to internal voice communications; the impact is moderate and generally recoverable, and the likelihood is low. Exposure falls within the organization's risk appetite.	Accept; monitor periodically.
RS-10	Router (Cisco ISR 4321)	Brute Force / Password Attack	Possible (3)	Critical (5)	15	High	Unacceptable	Threatens confidentiality and availability at the network core; administrative compromise enables traffic manipulation and outages affecting all dependent services — an infrastructure-level consequence for a single point of failure. Above appetite.	Forward for priority treatment.
RS-11	Employee Endpoints / Mobile	Social Engineering	Likely (4)	Moderate (3)	12	Medium	Tolerable	A Likely human-factor confidentiality risk; impact is contained to an individual endpoint and its access, but it remains a credible pivot toward wider compromise. Tolerable with awareness mitigation and oversight.	Schedule mitigation within a planned timeframe; management review.
RS-12	Printer (HP LaserJet)	Man-in-the-Middle	Unlikely (2)	Minor (2)	4	Very Low	Acceptable	A Minor, localized confidentiality exposure limited to documents transiting a single shared device; the incident is easily contained with negligible service or financial impact. Well within appetite.	Accept; periodic monitoring and basic hardening.

D.4 Risk Prioritization

The risks are ranked below from highest to lowest priority. Ranking is determined principally by risk score, with the impact rating used as the tiebreaker so that, where scores are equal, the scenario with the more severe consequence is addressed first. The ranking expresses the order in which the organization should direct its attention and resources.

Priority Rank	Risk ID	Asset	Risk Score	Risk Level	Priority Justification
1	RS-07	VPN / Remote Access	20	Critical	Joint-highest score (20, Critical) with the maximum impact rating (5). Trusted, internal-equivalent remote access means a single credential compromise becomes an organization-wide breach — the most severe consequence in the portfolio.
2	RS-02	Employee Endpoints	20	Critical	Joint-highest score (20, Critical), driven by a Very Likely rating. The near-certainty of a successful phishing attempt over an annual horizon, combined with PDPA/GDPR exposure, makes it a top organizational priority.
3	RS-01	Web Server (DMZ)	16	High	Highest-scoring High risk (16). A Likely, Internet-facing availability threat that directly interrupts customer revenue and damages reputation, with no upstream DDoS protection currently in place.
4	RS-03	Storage Server (DMZ)	15	High	High (15) with Critical impact (5). Potential encryption of both primary data and backups could render information unrecoverable and halt operations, with costs exceeding RM 1M.
5	RS-04	Application Server (DMZ)	15	High	High (15) with Critical impact (5). Direct compromise of restricted customer PII and financial records threatens both

Priority Rank	Risk ID	Asset	Risk Score	Risk Level	Priority Justification
					confidentiality and integrity, carrying regulatory and contractual consequences.
6	RS-10	Router (Cisco ISR 4321)	15	High	High (15) with Critical impact (5). Administrative compromise of the core router is an infrastructure-level, single-point-of-failure consequence; ranked alongside RS-03 and RS-04 and only marginally below them on recovery considerations.
7	RS-05	Wi-Fi Router / Clients	12	Medium	Medium (12) with Major impact (4). A contained wireless-confidentiality risk that is significant but limited to wireless-adjacent assets.
8	RS-06	Internal Switches / LAN	12	Medium	Medium (12) with Major impact (4). Lateral malware spread on the flat network could disrupt multiple systems, but the threat is routine and partially mitigated at the endpoint.
9	RS-11	Employee Endpoints / Mobile	12	Medium	Medium (12), likelihood-driven (Likely) with Moderate impact. A frequent human-factor risk whose consequence is contained to an individual endpoint.
10	RS-08	Firewall (FortiGate 100F)	10	Medium	Medium (10). Critical potential impact but Unlikely occurrence places it at the Medium/High boundary; priority hinges on maintaining patch posture.
11	RS-09	IP Phone / Telephony	6	Low	Low (6). A moderate, recoverable confidentiality impact with low likelihood; within appetite and managed by monitoring.
12	RS-12	Printer (HP LaserJet)	4	Very Low	Very Low (4). A minor, localized exposure with negligible business impact; the lowest priority in the portfolio.

D.5 Top Five Risks

The five highest-priority risks below represent the organization's most significant exposures and warrant the closest management attention in the next phase. Each is summarized with its analyzed values and a justification explaining why it ranks among the most critical.

1. RS-07 — VPN / Remote Access (VPN Credential Theft)

Risk Score	20	Risk Level	Critical
Likelihood	Likely (4)	Impact	Critical (5)

Justification. Joint-highest score (20, Critical) with the maximum impact rating (5). Trusted, internal-equivalent remote access means a single credential compromise becomes an organization-wide breach — the most severe consequence in the portfolio. A Likely confidentiality threat granting trusted, internal-equivalent access; compromise enables an organization-wide breach across multiple data categories with severe regulatory, financial and reputational consequences. The maximal-impact, high-likelihood profile makes it unacceptable.

2. RS-02 — Employee Endpoints (Phishing / Spear-Phishing)

Risk Score	20	Risk Level	Critical
Likelihood	Very Likely (5)	Impact	Major (4)

Justification. Joint-highest score (20, Critical), driven by a Very Likely rating. The near certainty of a successful phishing attempt over an annual horizon, combined with PDPA/GDPR exposure, makes it a top organizational priority. A Very Likely confidentiality threat; credential compromise opens a path to systems holding customer and employee PII, creating regulatory exposure under PDPA/GDPR alongside fraud and reputational harm. Unacceptable under any condition.

3. RS-01 — Web Server (DMZ) (DDoS Attack)

Risk Score	16	Risk Level	High
Likelihood	Likely (4)	Impact	Major (4)

Justification. Highest-scoring High risk (16). A Likely, Internet-facing availability threat that directly interrupts customer revenue and damages reputation, with no upstream DDoS protection currently in place. Threatens the availability of the public Web Server (SV-01); a sustained outage halts customer-facing transactions, causing direct revenue loss in the RM 100K–1M band and reputational damage. Availability-driven and above the organization's appetite for Internet-facing services.

4. RS-03 — Storage Server (DMZ) (Ransomware)

Risk Score	15	Risk Level	High
Likelihood	Possible (3)	Impact	Critical (5)

Justification. High (15) with Critical impact (5). Potential encryption of both primary data and backups could render information unrecoverable and halt operations, with costs exceeding RM 1M. Endangers the availability and integrity of corporate data and backups; a successful event would halt dependent operations, incur ransom and recovery costs exceeding RM 1M, and may be unrecoverable. Impact-driven and above appetite.

5. RS-04 — Application Server (DMZ) (SQL Injection)

Risk Score	15	Risk Level	High
Likelihood	Possible (3)	Impact	Critical (5)

Justification. High (15) with Critical impact (5). Direct compromise of restricted customer PII and financial records threatens both confidentiality and integrity, carrying regulatory and contractual consequences. Threatens the confidentiality and integrity of restricted customer PII and financial records via the Application Server; exploitation carries regulatory penalties, contractual liability and reputational loss. Above appetite.

D.6 Risk Matrix

The 5×5 matrix positions every evaluated risk by its likelihood and impact, reproducing the analyzed ratings. Cell color denotes the resulting risk level, and the scenario identifiers reveal where risk concentrates: toward the upper-right quadrant, where high-likelihood, high-impact exposures (RS-02, RS-07) demand the greatest attention.

Likelihood ↓ / Impact →	1 Negligible	2 Minor	3 Moderate	4 Major	5 Critical
5 Very Likely	5	10	15	20 RS-02	25
4 Likely	4	8	12 RS-11	16 RS-01	20 RS-07
3 Possible	3	6	9	12 RS-05, RS-06	15 RS-03, RS-04, RS-10
2 Unlikely	2	4 RS-12	6 RS-09	8	10 RS-08
1 Rare	1	2	3	4	5

Legend: Critical (20–25) High (15–19) Medium (10–14) Low (5–9) Very Low (1–4).

D.7 Risk Evaluation Summary

The evaluation confirms that AL-ITTIHAD's overall risk posture is elevated but well differentiated. Of the twelve evaluated scenarios, six are Unacceptable (two Critical and four High), four are Tolerable (Medium) and two are Acceptable (one Low and one Very Low). Half of the portfolio therefore exceeds the organization's risk appetite and requires treatment, signaling a posture that demands prompt and prioritized action rather than routine monitoring alone.

The major finding is that the most severe risks concentrate at the boundary between the organization and the outside world and at its infrastructure core: remote access (RS-07), employee-targeted phishing (RS-02), the public web service (RS-01), and the data-bearing and routing assets (RS-03, RS-04, RS-10). These exposures share a small set of underlying weaknesses — absent multi-factor authentication, limited network segmentation, and unverified backup and patch resilience — which means that addressing a few systemic gaps would reduce several high-ranked risks at once.

In terms of distribution, the portfolio now spans all five risk levels, with the mass of risk sitting in the High and Medium bands and only two scenarios within appetite. The matrix shows a clear upward-right concentration, confirming that likelihood and impact reinforce one another in the most serious cases rather than offsetting.

For these reasons, the highest-ranked risks — particularly the two Critical scenarios (RS-07 and RS-02) and the leading High scenario (RS-01) should receive priority attention in the next phase. They combine the greatest likelihood and consequence, the broadest potential for cascading organizational impact, and the clearest breaches of acceptance criteria, and they therefore represent the most rational starting point for risk treatment. The prioritized output of this evaluation provides the direct, decision-ready input into that phase.

Section E: Risk Treatment

E.1 Risk Treatment Introduction

Risk Treatment is the fifth phase of the ISO/IEC 27005 risk management process and follows directly from the Risk Evaluation in Section D. Whereas evaluation decided which risks are acceptable and which exceed AL-ITTIHAD's appetite, treatment determines how the unacceptable and tolerable risks will be addressed. Its purpose is to select and plan the actions that bring each risk to a level the organization is willing to accept, using the assets, threats, vulnerabilities and analyzed risk values already established earlier in the report.

Treatment reduces organizational exposure by acting on the two dimensions of risk identified during analysis. A control may lower the likelihood of a scenario — for example, by removing the vulnerability an attacker would exploit — or it may lower the impact, by limiting the consequence once an event occurs, or it may do both. By targeting the specific threat-and-vulnerability pairing behind each scenario, the plan converts the prioritized findings of Section D into concrete, owner-assigned actions.

The objective is not to eliminate risk, which is neither achievable nor cost-effective, but to reduce each risk to an acceptable residual level commensurate with its business significance. The remainder of this section sets out the available treatment approaches, the criteria used to choose between them, a treatment plan for the prioritized risks, an assessment of the residual risk that remains, the order in which treatment should proceed, and a concluding summary.

E.2 Risk Treatment Approaches

Consistent with ISO/IEC 27005, four standard treatment options are available. The appropriate option for each risk depends on its level, the cost and feasibility of controls, and the organization's priorities.

Treatment Option	Definition	Purpose	When Appropriate
Risk Reduction / Mitigation	Applying controls that lower the likelihood and/or impact of the risk.	To bring a risk that exceeds appetite down to an acceptable residual level.	The default choice for Critical, High and most medium risks where effective controls are feasible and cost justified.
Risk Avoidance	Eliminating the risk by discontinuing or redesigning the activity or asset that gives rise to it.	To remove exposure entirely where it cannot be tolerated or economically mitigated.	When a risk is severe and no proportionate control exists, or the activity's value does not justify its exposure.
Risk Transfer / Sharing	Shifting part of the consequence to a third party, e.g. through cyber-insurance or outsourcing.	To share the financial or operational burden of risks that controls cannot fully remove.	For high-impact, low-frequency risks (such as ransomware) where residual financial loss remains after mitigation.
Risk Acceptance	Formally retaining the risk without further treatment, under monitoring.	To avoid disproportionate, spend on risks already within appetite.	For Low and Very Low risks, or where the cost of treatment exceeds the benefit.

E.3 Risk Treatment Decision Criteria

The selection of a treatment option for each risk was guided by a consistent set of criteria rather than by any single factor. The risk level established in Section C is the primary driver: Critical and High risks, being unacceptable, default to mitigation or, where appropriate, transfer, whereas Low and Very Low risks are candidates for acceptance. Within that framing, the business and operational impact of the scenario is weighed — risks that threaten customer-facing services, core infrastructure or regulated data justify stronger and faster intervention than those with localized, recoverable consequences.

A cost-versus-benefit judgment then tests whether the expected reduction in exposure justifies the investment in controls; treatment is not pursued where its cost would exceed the value of the risk it removes. Regulatory requirements raise the priority of risks affecting personal data, since obligations under the PDPA and GDPR make certain exposures effectively intolerable regardless of their raw score. Finally, organizational priorities and the feasibility of implementation determine sequencing: controls that are practical, that reuse existing capability, and that reduce several risks at once are preferred and scheduled earlier. Applying these criteria produced the treatment decisions recorded in the plan that follows.

E.4 Risk Treatment Plan

The plan below addresses the prioritized risks, focusing on the Critical and High exposures and the medium risks where treatment or monitoring is justified; the Low and Very Low risks are included for completeness with an acceptance-and-monitoring disposition. All risk levels are carried unchanged from the analysis; the controls, ownership, timeline and residual estimates are the treatment decisions of this phase. Detailed ISO control mapping is intentionally out of scope here.

Risk ID	Asset	Threat	Risk Level	Selected Treatment Option	Proposed Controls	Control Type	Justification	Risk Owner	Implementation Timeline	Expected Residual Risk	Monitoring / Review Method
RS-07	VPN / Remote Access	VPN Credential Theft	Critical	Risk Reduction (Mitigation)	Enforce multi-factor authentication, a strong password policy, account lockout, and remote-session monitoring.	Preventive + Detective	Closes the decisive missing control (MFA) against credential theft (T-12, V-07); even a stolen password no longer yields trusted internal access, sharply reducing the organization-wide confidentiality exposure.	IT Dept. (Network & Security) / CISO	Immediate (0–1 month)	Low	VPN authentication logs; anomalous-session alerts; quarterly remote-access reviews.
RS-02	Employee Endpoints	Phishing / Spear-Phishing	Critical	Risk Reduction (Mitigation)	Enforce multi-factor authentication, mandatory recurring awareness training with phishing simulations, and strengthened email filtering / anti-spoofing.	Preventive + Deterrent	Addresses low awareness (V-09) and the absence of MFA: training reduces likelihood of a successful lure, while MFA contains the impact of any disclosed credential, protecting confidentiality.	CISO / IT Security (Awareness)	Immediate (0–1 month)	Low	Quarterly phishing-simulation click-rates; training completion metrics; authentication anomaly alerts.
RS-01	Web Server (DMZ)	DDoS Attack	High	Risk Reduction (Mitigation)	Upstream DDoS scrubbing / CDN, traffic rate-limiting, firewall rule hardening, and continuous traffic monitoring.	Preventive + Detective	Directly counters volumetric flooding (T-01) and the permissive firewall rules (V-03) by absorbing and filtering malicious traffic before it reaches the server, protecting availability of customer-facing services.	CISO	Short term (1–3 months)	Low	Real-time traffic dashboards; monthly availability review; periodic DDoS-response drills.
RS-03	Storage Server (DMZ)	Ransomware	High	Risk Reduction + Risk Transfer	Immutable, tested offline backups; endpoint detection & response (EDR);	Corrective + Preventive	Counters ransomware (T-03) and the lack of recoverable backups (V-	IT Dept. (Infrastructure)	Short term (1–3 months)	Medium	Scheduled backup-restore tests;



Risk ID	Asset	Threat	Risk Level	Selected Treatment Option	Proposed Controls	Control Type	Justification	Risk Owner	Implementation Timeline	Expected Residual Risk	Monitoring / Review Method
					encryption at rest; a formal incident-response plan; complemented by cyber-insurance to share residual financial loss.		04): immutable backups assure recovery (availability/integrity) while transfer shares the financial consequence that controls cannot fully remove.				EDR alert review; annual incident-response exercises.
RS-04	Application Server (DMZ)	SQL Injection	High	Risk Reduction (Mitigation)	Input validation / parameterized queries, a Web Application Firewall (WAF), a secure-coding standard, and periodic application security testing.	Preventive + Detective	Directly remediates improper input validation (V-06), preventing injected SQL from reaching the database and protecting the confidentiality and integrity of restricted customer and financial data.	IT Dept. (Application Services)	Short term (1–3 months)	Low	WAF event logs; periodic vulnerability scans and penetration testing.
RS-10	Router (Cisco ISR 4321)	Brute Force / Password Attack	High	Risk Reduction (Mitigation)	Out-of-band management access, account lockout and MFA on management interfaces, and management-interface access-control lists.	Preventive	Removes the weak-password exposure (V-07) on the core router's management interface, preventing administrative compromise and protecting confidentiality and availability of routing.	IT Infrastructure Manager	Short term (1–3 months)	Low	Management-access logs; periodic configuration and ACL audit.
RS-05	Wi-Fi Router / Clients	Man-in-the-Middle	Medium	Risk Reduction (Mitigation)	WPA2/WPA3-Enterprise authentication, periodic key rotation, removal of default credentials, and wireless intrusion monitoring.	Preventive	Eliminates weak/default Wi-Fi credentials (V-02), preventing rogue association and interception, thereby protecting the confidentiality of wireless traffic.	IT Dept. (Network)	Medium term (3–6 months)	Low	Wireless IDS logs; periodic wireless configuration audit.
RS-06	Internal Switches / LAN	Malware / Trojan	Medium	Risk Reduction (Mitigation)	VLAN segmentation, Network Access Control (NAC), endpoint detection & response, and removable-media controls.	Preventive + Detective	Addresses the lack of segmentation (V-08) so that a single infection cannot propagate across a flat network, containing integrity and availability impact.	IT Dept. (Network)	Medium term (3–6 months)	Low	EDR and NAC dashboards; periodic segmentation audit.
RS-11	Employee Endpoints / Mobile	Social Engineering	Medium	Risk Reduction (Mitigation)	Awareness training with identity-verification / call-back procedures, and restrictions on endpoint software installation.	Preventive + Deterrent	Builds the verification behaviors absent under V-09 so staff resist impersonation, and limits what a manipulated user	CISO / IT Security (Awareness)	Medium term (3–6 months)	Low	Training metrics; simulated pretext-call exercises.



Risk ID	Asset	Threat	Risk Level	Selected Treatment Option	Proposed Controls	Control Type	Justification	Risk Owner	Implementation Timeline	Expected Residual Risk	Monitoring / Review Method
							can install, reducing the likelihood and reach of compromise.				
RS-08	Firewall (FortiGate 100F)	Zero-Day Exploit	Medium	Risk Reduction (Mitigation)	A disciplined patch-management cadence, vendor threat-intelligence subscription, management-plane segmentation, and intrusion prevention; segmentation acts as a compensating control until patches are available.	Preventive + Compensating	Reduces the window of exposure to firewall zero-days (T-10) by minimizing patch latency and isolating the management plane, limiting both likelihood and the reach of any compromise.	IT Dept. (Network & Security)	Medium term (3–6 months)	Medium	Patch-compliance reports; threat-intelligence feeds; periodic firewall configuration review.
RS-09	IP Phone / Telephony	Insider Threat	Low	Risk Acceptance (with monitoring)	Voice/data VLAN separation and call-access logging where cost-justified; otherwise retained at current control level.	Detective	The analyzed risk is Low and within appetite; active monitoring is more proportionate than costly redesign, so the risk is accepted with detective oversight.	IT Dept. (Infrastructure) / HR	Routine (6–12 months)	Low	Periodic call-access log review; periodic access-rights review.
RS-12	Printer (HP LaserJet)	Man-in-the-Middle	Very Low	Risk Acceptance (with monitoring)	Enable printer management authentication and secure/pull printing, and isolate the printer by VLAN as routine hardening.	Preventive	The analyzed risk is Very Low and well within appetite; basic hardening during routine maintenance is sufficient and active treatment is not warranted.	IT Dept. (Infrastructure)	Ongoing monitoring	Very Low	Periodic printer configuration check.

E.5 Residual Risk Assessment

Residual risk is the exposure that remains after the selected controls have been implemented. It exists because no control is perfect: controls reduce but rarely eliminate likelihood or impact, some threats (such as zero-day exploits) cannot be wholly prevented, and the cost of pursuing the last increment of risk reduction is seldom justified. The aim of treatment is therefore to reduce each risk to a residual level that falls within the organization's appetite, not to drive it to zero.

The table below estimates the residual risk level expected once the planned treatment is in place. These estimates are forward-looking judgments based on the effectiveness of the proposed controls; they do not alter the original analyzed risk levels, which remain as recorded in Section C. Any residual risk that remains above appetite after treatment must be formally accepted by management and kept under active review.

Risk ID	Original Risk Level	Treatment Applied	Expected Residual Risk Level	Residual Risk Justification
RS-01	High	Risk Reduction (Mitigation)	Low	DDoS scrubbing and rate-limiting absorb most attack traffic; some availability risk persists during very large or novel attacks.
RS-02	Critical	Risk Reduction (Mitigation)	Low	MFA neutralizes most credential reuse and training cuts click-rates; a small human-factor residual remains.
RS-03	High	Risk Reduction + Risk Transfer	Medium	Immutable backups and EDR assure recovery, but ransomware remains a high-impact threat, leaving a contained residual that transfer partly offsets.
RS-04	High	Risk Reduction (Mitigation)	Low	Input validation and a WAF close the injection path; residual is limited to undiscovered application flaws.
RS-05	Medium	Risk Reduction (Mitigation)	Low	Enterprise authentication removes the enabling weakness; residual interception risk is minimal.

Risk ID	Original Risk Level	Treatment Applied	Expected Residual Risk Level	Residual Risk Justification
RS-06	Medium	Risk Reduction (Mitigation)	Low	Segmentation and NAC contain lateral spread; residual is limited to a single infected host.
RS-07	Critical	Risk Reduction (Mitigation)	Low	MFA removes the decisive exposure, so a stolen password no longer grants access; residual is low.
RS-08	Medium	Risk Reduction (Mitigation)	Medium	Patch discipline and management-plane isolation shrink the exposure window, but zero-day risk cannot be fully eliminated.
RS-09	Low	Risk Acceptance (with monitoring)	Low	Accepted within appetite; monitoring keeps the already-low insider exposure visible.
RS-10	High	Risk Reduction (Mitigation)	Low	Out-of-band management and lockout/MFA prevent brute-force compromise; residual is low.
RS-11	Medium	Risk Reduction (Mitigation)	Low	Verification behaviors and install restrictions reduce susceptibility; a modest human-factor residual remains.
RS-12	Very Low	Risk Acceptance (with monitoring)	Very Low	Accepted within appetite; basic hardening keeps the minor exposure negligible.

E.6 Treatment Prioritization

Treatment activities are sequenced below from highest to lowest priority. Critical risks are scheduled first, High risks second and medium risks thereafter, with the accepted Low and Very Low risks handled through routine monitoring. The ordering reflects both severity and the business value of the assets protected.

Priority Rank	Risk ID	Treatment Strategy	Implementation Priority	Justification
1	RS-07	Risk Reduction (Mitigation)	Immediate	Critical, maximal-impact remote-access exposure; MFA is a fast, high-leverage control that prevents organization-wide breach.
2	RS-02	Risk Reduction (Mitigation)	Immediate	Critical, near-certain phishing vector; MFA and training are urgent and reduce multiple downstream risks.
3	RS-01	Risk Reduction (Mitigation)	High	Highest High-band risk; protects customer-facing revenue and reputation from availability loss.
4	RS-03	Risk Reduction + Risk Transfer	High	High, potentially unrecoverable data loss; backup and recovery resilience is foundational.
5	RS-04	Risk Reduction (Mitigation)	High	High, restricted-data exposure; application controls protect regulated customers and financial data.
6	RS-10	Risk Reduction (Mitigation)	High	High, infrastructure single point of failure; management hardening prevents core-network compromise.
7	RS-05	Risk Reduction (Mitigation)	Medium	Medium; contained wireless confidentiality risk addressed by authentication hardening.
8	RS-06	Risk Reduction (Mitigation)	Medium	Medium; segmentation limits malware spread and reduces several lateral-movement paths.
9	RS-11	Risk Reduction (Mitigation)	Medium	Medium; awareness controls reduce frequent human-factor exposure.
10	RS-08	Risk Reduction (Mitigation)	Medium	Medium at the boundary; patch discipline reduces a high impact but unlikely exposure.
11	RS-09	Risk Acceptance (with	Low (routine)	Low and within appetite;

Priority Rank	Risk ID	Treatment Strategy	Implementation Priority	Justification
		monitoring)		managed through monitoring rather than active treatment.
12	RS-12	Risk Acceptance (with monitoring)	Low (routine)	Very Low and within appetite; addressed by routine hardening only.

E.7 Risk Treatment Summary

The treatment strategy adopted across the portfolio is predominantly one of risk reduction through layered preventive and detective controls, complemented by risk transfer for the residual financial consequence of ransomware and by formal acceptance of the two risks already within appetite. A small number of high-leverage controls — multi-factor authentication, network segmentation, resilient and tested backups, application input validation, and consistent security-awareness training — recur across the plan and, between them, address many the organization's significant exposures.

Implemented as planned, these treatments are expected to reduce the organization's overall risk exposure substantially, moving the Critical and High risks into Low or, in the impact-bound cases, Medium residual territory, and confirming the medium risks at acceptable levels. This represents a material improvement in AL-ITTIHAD's security posture relative to the largely perimeter-weighted baseline identified earlier in the report.

The value of the plan, however, depends entirely on disciplined implementation in the prioritized order and on the assignment of clear ownership for each action. Equally important is continuous monitoring and review: residual risk must be tracked, control effectiveness verified through the methods specified in the plan, and the assessment revisited as the threat landscape, the asset base and the control environment evolve. Managed in this way, the treatment plan directly supports AL-ITTIHAD's cybersecurity objectives — protecting the confidentiality, integrity and availability of its information assets, sustaining customer and regulatory trust across its jurisdictions, and embedding risk management as an ongoing organizational discipline rather than a one-time exercise.

Section F: ISO/IEC 27002 Control Mapping

F.1 Introduction

This section maps the risk treatments selected in Section E to recognize information security controls drawn from ISO/IEC 27002. The purpose of control mapping is to demonstrate that the measures proposed to treat AL-ITTIHAD's risks are not ad-hoc but correspond to an internationally accepted catalogue of good practice, and to provide a traceable line of sight from each identified risk, through its chosen treatment, to the specific control that delivers that treatment. This traceability is essential for assurance: it allows management, auditors and certification bodies to confirm that every significant risk is addressed by a defined, recognized control.

Risk treatment and security control are two sides of the same activity. A treatment decision states the intent — to reduce, transfer or accept risk while a control is the concrete mechanism that realizes that intent. Controls are therefore selected because they directly counter the threat-and-vulnerability pairing behind a risk: each control either lowers the likelihood that a scenario occurs, reduces the impact if it does, or improves the organization's ability to detect and recover from it. Aligning these controls with ISO/IEC 27002 ensures that AL-ITTIHAD's treatment plan is consistent, comprehensive and defensible, supports its progression toward ISO/IEC 27001 certification, and provides demonstrable evidence of due diligence to the regulators whose regimes apply across the organization's jurisdictions.

F.2 ISO/IEC 27002 Overview

ISO/IEC 27002 is an internationally recognized code of practice that provides a catalogue of information security controls together with implementation guidance. It is the companion standard to ISO/IEC 27001: whereas 27001 specifies the requirements for an Information Security Management System (ISMS) and its risk-based approach, 27002 elaborates the controls an organization may select to treat the risks that the ISMS identifies. Its purpose is to give organizations a common, well-understood reference set of controls so that security measures are consistent, complete and benchmarked against good practice rather than invented in isolation.

In its current structure the standard organizes its controls into four themes — organizational, people, physical and technological — replacing the larger number of domains used in earlier versions while preserving equivalent coverage. Each control has a defined objective and may serve preventive, detective or corrective purposes. Within cybersecurity risk management the role of these controls is pivotal: they are the instruments through which assessed risk is reduced. Identifying and analyzing risk has no protective value until controls are implemented and operated, and it is the disciplined selection, implementation and review of controls that converts a risk assessment into measurable improvement in security posture.

F.3 Control Selection Methodology

Controls were not chosen generically but were selected to fit each risk's specific characteristics, following a consistent reasoning. The starting point was risk severity as established in Section C: Critical and High risks warranted the strongest and most immediate controls, whereas medium risks justified proportionate measures and the Low and Very Low risks required only light hardening alongside monitoring. Business impact and asset criticality then shaped the choice — controls protecting customer-facing services, regulated data and core infrastructure were prioritized, reflecting the High-criticality concentration identified in the asset inventory (Section A).

The nature of each vulnerability determined which control family was relevant: a human-factor weakness (V-09) points to awareness and authentication controls, a configuration weakness (V-03, V-08) points to network-security and configuration controls, and a technical application weakness (V-06) points to secure-development controls. Operational requirements were respected so that selected controls would be feasible within AL-ITTIHAD's environment and would not unduly disrupt the services they provide. Finally, the mapping was anchored to the treatment strategy already chosen in Section E, ensuring that the controls listed here are precisely those that deliver the planned mitigation, transfer or acceptance. The result is the risk-to-control mapping presented in F.4.

F.4 Risk-to-Control Mapping Table

The table maps every risk to the ISO/IEC 27002 control category and specific controls that implement its selected treatment. Control references follow the ISO/IEC 27002 numbering; risk levels and treatments are carried unchanged from Sections C and E.

Risk ID	Asset	Threat	Treatment Applied	ISO/IEC 27002 Control Category	Selected Control(s)	Control Objective	Justification
RS-01	Web Server (DMZ)	DDoS Attack	Risk Reduction (Mitigation)	Network Security	8.20 Networks security; 8.21 Security of network services; 8.16 Monitoring activities; 8.6 Capacity management	Protect the availability of network services and detect anomalous traffic before it exhausts capacity.	DDoS scrubbing, rate-limiting and capacity headroom operationalize network-security and capacity controls, while monitoring provides the detection the current baseline lacks.
RS-02	Employee Laptops / Desktop PCs	Phishing / Spear-Phishing	Risk Reduction (Mitigation)	Security Awareness / Access Control	6.3 Awareness, education and training; 8.5 Secure authentication (MFA); 8.23 Web filtering; 5.17 Authentication information	Reduce human susceptibility to deception and contain the impact of any disclosed credential.	Recurring awareness training reduces the likelihood of a successful lure, while MFA and web filtering directly counter credential reuse — the controls absent from the baseline (V-09).
RS-03	Storage Server (DMZ)	Ransomware	Risk Reduction + Transfer	Backup Management / Malware Protection	8.13 Information backup; 8.7 Protection against malware; 8.24 Use of cryptography; 5.26 Response to incidents; 5.30 ICT readiness for continuity	Assure recoverability of data and prevent, detect and recover from malware that targets data and backups.	Immutable, tested backups and ICT-continuity controls guarantee recovery despite encryption (addressing V-04), malware protection lowers likelihood, and transfer shares the residual financial loss.
RS-04	Application Server (DMZ)	SQL Injection	Risk Reduction (Mitigation)	Secure Configuration / Secure Development	8.28 Secure coding; 8.26 Application security requirements; 8.29 Security testing in development and acceptance; 8.27 Secure system architecture	Prevent injections by validating input and assuring application security throughout the lifecycle.	Input validation, a WAF and secure-coding practices remediate improper input validation (V-06), and security testing verifies the high-value data store is protected.
RS-05	Wi-Fi Router / Wireless Clients	Man-in-the-Middle (MitM)	Risk Reduction (Mitigation)	Network Security	8.20 Networks security; 8.24 Use of cryptography; 5.17 Authentication information	Secure wireless communications and authentication so traffic cannot be intercepted.	Enterprise authentication and key rotation eliminate weak/default Wi-Fi credentials (V-02), preventing rogue association and interception.
RS-06	Internal Switches / Internal LAN	Malware / Trojan	Risk Reduction (Mitigation)	Network Security / Malware Protection	8.22 Segregation of networks; 8.7 Protection against malware; 8.20 Networks security	Contain lateral movement and detect malicious code on the internal network.	VLAN segregation directly addresses the lack of segmentation (V-08) so a single infection cannot reach critical servers, while malware protection lowers likelihood.
RS-07	VPN / Remote Access (Remote Employees)	VPN Credential Theft	Risk Reduction (Mitigation)	Access Control	8.5 Secure authentication (MFA); 5.17 Authentication information; 5.15 Access control; 8.16 Monitoring activities	Prevent unauthorized remote access and detect misuse of remote sessions.	MFA and a strong password policy close the decisive gap behind credential theft (V-07); session monitoring provides detection. A stolen password alone no longer grants trusted access.
RS-08	Firewall (FortiGate 100F)	Zero-Day Exploit	Risk Reduction (Mitigation)	Vulnerability Management / Secure	8.8 Management of technical vulnerabilities; 8.9	Minimize the exposure window to vulnerabilities	A disciplined patch cadence and threat intelligence shrink the zero-day window (T-10),

Risk ID	Asset	Threat	Treatment Applied	ISO/IEC 27002 Control Category	Selected Control(s)	Control Objective	Justification
				Configuration	Configuration management; 5.7 Threat intelligence; 8.22 Segregation of networks	and harden the perimeter device configuration.	while management-plane segregation limits the reach of any compromise.
RS-09	IP Phone / Internal Communications	Insider Threat	Risk Acceptance (with monitoring)	Access Control / Logging and Monitoring	8.22 Segregation of networks; 8.15 Logging; 8.2 Privileged access rights; 5.18 Access rights	Limit and record insider access to the telephony segment.	Voice/data segregation and call-access logging provide detective oversight proportionate to a Low risk that is accepted within appetite.
RS-10	Router (Cisco ISR 4321)	Brute Force / Password Attack	Risk Reduction (Mitigation)	Access Control / Network Security	8.5 Secure authentication; 8.2 Privileged access rights; 8.20 Networks security; 8.15 Logging	Protect the router management plane from credential-guessing attacks.	Out-of-band management, lockout/MFA and ACLs remove the weak-password exposure (V-07) on the core router's management interface, preventing administrative compromise.
RS-11	Employee Laptops / Mobile Devices	Social Engineering	Risk Reduction (Mitigation)	Security Awareness / Secure Configuration	6.3 Awareness, education and training; 5.17 Authentication information; 8.19 Installation of software on operational systems	Build verification behaviors and limit what a manipulated user can install.	Awareness training with call-back verification addresses low awareness (V-09), while software-installation restrictions limit the reach of a manipulated user.
RS-12	Printer (HP LaserJet Pro M404dn)	Man-in-the-Middle (MitM)	Risk Acceptance (with monitoring)	Secure Configuration	8.9 Configuration management; 8.22 Segregation of networks; 5.15 Access control	Secure the printer's configuration and isolate it on the network.	Management authentication, secure printing and VLAN isolation harden the unsecured printing services (V-12); proportionate to a Very Low risk accepted within appetite.

F.5 Control Justification

The controls mapped above fall into eight principal categories. Each is discussed below in terms of why it was selected, the risks it addresses, its expected effectiveness and its contribution to reducing AL-ITTIHAD's overall risk exposure.

F.5.1 Access Control

Access control (ISO/IEC 27002 5.15, 5.18, 8.2, 8.5, 5.17) was selected because the most severe risks in the portfolio turn on the misuse of identities and credentials. It directly addresses VPN credential theft (RS-07), router brute-force compromise (RS-10), phishing-enabled access (RS-02) and insider abuse (RS-09). Its central mechanism — multi-factor authentication, backed by a strong password policy, account lockout and privileged-access restriction — is highly effective because it breaks the link between a stolen or guessed password and actual access, which is the common pathway across these scenarios. Its contribution is disproportionately large: a single control family neutralizes the decisive weakness behind two Critical and two High/Low risks, making it the highest-leverage investment in the plan.

F.5.2 Network Security

Network security controls (8.20, 8.21, 8.22, 8.6) were selected to protect availability and to contain movement across the network. They address the DDoS threat to the web service (RS-01), wireless interception (RS-05), malware propagation on the flat LAN (RS-06) and, through management-plane segregation, the firewall and router risks (RS-08, RS-10). Their expected effectiveness is high for containment: network segregation in particular converts a single compromise from an estate-wide event into an isolated one, while rate-limiting and capacity controls blunt volumetric attacks. Their contribution is both preventive and structural, reducing the blast radius of several scenarios simultaneously.

F.5.3 Backup Management

Backup management (8.13, with 5.30 ICT readiness for continuity) was selected specifically to counter the ransomware risk to the storage server (RS-03), the scenario with the most severe impact in the portfolio. Immutable, regularly tested backups are the control that most directly addresses the inability to recover (V-04): even if data is encrypted, recovery is assured. Their effectiveness in reducing impact is decisive, although they do not reduce the likelihood of infection, which is why they are paired with malware protection and incident management. Their contribution is to transform a potentially unrecoverable, business-critical event into a recoverable disruption.

F.5.4 Logging and Monitoring

Logging and monitoring controls (8.15, 8.16) were selected because the baseline assessment found detective capability to be weak across the environment. They support detection for remote-access misuse (RS-07), router and firewall management activity (RS-08, RS-10) and insider telephony abuse (RS-09). Their effectiveness lies less in prevention than in reducing the time an attacker remains undetected, thereby limiting cumulative impact and enabling timely response. Their contribution is to provide the visibility on which every other control's assurance ultimately depends.

F.5.5 Security Awareness

Security awareness controls (6.3) were selected because human-factor vulnerability (V-09) underpins the two most behaviorally driven risks — phishing (RS-02) and social engineering (RS-11). Recurring training and phishing simulations are effective in measurably lowering click-rates and building the verification behaviors that resist impersonation. Because awareness reduces the likelihood at the very first step of these attack chains, its contribution is preventive and broad, complementing the technical containment that MFA provides.

F.5.6 Vulnerability Management

Vulnerability management (8.8, with 5.7 threat intelligence) was selected to address the firewall zero-day exposure (RS-08) and, more generally, the unpatched software weakness present across assets. A disciplined patch cadence and vendor threat-intelligence reduce the window during which a known vulnerability can be exploited. Its effectiveness against true zero-days is inherently partial, which is why it is reinforced by segregation as a compensating control, but its contribution to shrinking the overall exposure surface is significant and ongoing.

F.5.7 Incident Management

Incident management (5.26 response to incidents, with continuity readiness) was selected because the baseline lacked a formal response capability, and because the highest-impact scenarios — ransomware (RS-03) and perimeter compromise (RS-08) depend on swift, structured response to limit damage. A tested incident-response plan improves both containment and recovery, reducing the duration and cost of an event. Its contribution is to ensure that, when prevention fails, the consequence is minimized rather than allowed to escalate.

F.5.8 Secure Configuration

Secure configuration controls (8.9, with secure-development controls 8.26–8.29) were selected to remediate configuration and application weaknesses — misconfigured firewall rules (V-03), improper input validation (V-06) and unsecured printing services (V-12) — affecting RS-04, RS-08 and RS-12. Hardened, validated configurations remove the exploitable conditions at source, which makes them highly effective preventive controls. Their contribution is foundational: by eliminating the underlying weakness rather than compensating for it, they reduce the likelihood of several scenarios at their root.

F.6 Control Effectiveness Discussion

Taken together, the selected controls act across the full lifecycle of a security event — before, during and after — and their expected effects can be examined along five dimensions.

Reduction of likelihood. Preventive controls attack the probability that a scenario occurs. Multi-factor authentication, secure configuration, input validation, enterprise wireless authentication and security-awareness training each remove or weaken the specific vulnerability an attacker would exploit, so that scenarios such as phishing (RS-02), credential theft (RS-07), injection (RS-04) and brute-force (RS-10) become substantially less probable.

Reduction of impact. Where an event cannot be wholly prevented, containment and recovery controls limit its consequence. Network segregation confines malware or intrusion to a single segment (RS-06, RS-08), immutable backups guarantee recovery from ransomware (RS-03), and risk transfer absorbs residual financial loss. These controls lower the impact dimension even when likelihood is unchanged.

Improved resilience. Controls such as capacity management, backup and ICT-continuity readiness ensure that services can withstand and continue through disruptive events, so that an attack degrades rather than halts operations — most notably for the public web service (RS-01) and the storage service (RS-03).

Improved detection. Logging, monitoring and intrusion detection shorten the interval between compromise and discovery. Applied to remote access, management interfaces and wireless segments, they convert previously silent exposures (RS-07, RS-09, RS-10) into observable, alterable events, which is a precondition for limiting cumulative damage.

Improved recovery. Incident management and tested backups provide a structured route back to normal operation. Their presence ensures that, following a ransomware or perimeter event, AL-ITTIHAD can restore data and services within a planned timeframe rather than improvising under pressure, directly reducing downtime and cost.

The controls are deliberately layered: prevention reduces frequency, detection limits duration, and resilience and recovery limit consequences. This defense-in-depth means that the failure of any single control does not expose the organization fully, and it is the combined effect — rather than any individual control — that drives the residual-risk reductions estimated in Section G.

F.6.1 Control Implementation Roadmap

The phased roadmap below sequences the selected controls by priority. Phase 1 addresses the Critical risks, Phase 2 the High risks, Phase 3 the medium risks, and Phase 4 the accepted Low and Very Low risks. Risk levels, controls and timelines are carried unchanged from Sections C, E and F.

Priority	Risk ID	Control	Responsible Team	Implementation Timeline	Expected Outcome	Status
1	RS-07	MFA, strong password policy, account lockout and session monitoring (8.5, 5.17, 5.15)	Security Operations Team	Immediate (0–1 month)	Trusted remote access protected; residual reduced to Low.	Planned – Phase 1
1	RS-02	MFA, recurring awareness training and email/web filtering (6.3, 8.5, 8.23)	CISO / IT Security Team	Immediate (0–1 month)	Phishing success and credential reuse cut; residual reduced to Low.	Planned – Phase 1
2	RS-01	DDoS scrubbing/CDN, rate-limiting, firewall hardening and monitoring (8.20, 8.21, 8.16)	Network Administrator	Short term (1–3 months)	Website availability protected; residual reduced to Low.	Planned – Phase 2
2	RS-03	Immutable tested backups, EDR, encryption and incident response (8.13, 8.7, 5.26)	IT Infrastructure Team	Short term (1–3 months)	Recovery assured; residual reduced to Medium (transfer covers residual loss).	Planned – Phase 2
2	RS-04	Input validation, WAF, secure coding and security testing (8.28, 8.26, 8.29)	Database Administrator	Short term (1–3 months)	Injection path closed; residual reduced to Low.	Planned – Phase 2
2	RS-10	Out-of-band management, lockout/MFA and management ACLs (8.5, 8.2, 8.20)	Network Administrator	Short term (1–3 months)	Router management protected; residual reduced to Low.	Planned – Phase 2
3	RS-05	WPA2/WPA3-Enterprise authentication and key rotation (8.20, 8.24, 5.17)	Network Administrator	Medium term (3–6 months)	Wireless interception prevented; residual reduced to Low.	Planned – Phase 3
3	RS-06	VLAN segmentation, NAC and EDR (8.22, 8.7, 8.20)	Network Administrator	Medium term (3–6 months)	Lateral spread contained; residual reduced to Low.	Planned – Phase 3
3	RS-11	Awareness training with verification and install restrictions (6.3, 8.19)	IT Security Team	Medium term (3–6 months)	Manipulation susceptibility reduced; residual reduced to Low.	Planned – Phase 3
3	RS-08	Patch management, threat intelligence and management-plane segregation (8.8, 8.9, 5.7, 8.22)	IT Security Team	Medium term (3–6 months)	Exposure window minimized; residual held at Medium.	Planned – Phase 3
4	RS-09	Voice/data VLAN separation and call-access logging (8.22, 8.15)	IT Infrastructure Team	Routine (6–12 months)	Insider exposure monitored; residual remains Low (accepted).	Planned – Phase 4
4	RS-12	Printer management authentication, secure printing and VLAN isolation (8.9, 8.22)	System Administrator	Ongoing monitoring	Minor exposure hardened; residual remains Very Low (accepted).	Planned – Phase 4

Roadmap Analysis

The roadmap priorities controls strictly according to the risk levels established in the analysis, so that effort is directed first to the exposures that most threaten the organization. The two Critical risks (RS-07 and RS-02) are scheduled for immediate implementation because they combine high likelihood with severe, organization-wide consequences, and because their principal control — multi-factor authentication — is fast to deploy and delivers disproportionate benefit. The four High risks follow in the short term, addressing customer-facing availability, data recoverability, application integrity and core-network protection. Medium risks are scheduled in the medium term, and the accepted Low and Very Low risks are placed in an ongoing monitoring phase rather than active remediation.

Sequencing the work in this way yields several organizational benefits. It front-loads the largest reductions in exposure, so that the steepest improvement in security posture is achieved earliest; it allows a small number of high-leverage controls — MFA, segmentation, resilient backups and awareness training — to be deployed first, simultaneously reducing several risks; and it aligns expenditure and team effort with business value, concentrating scarce resources where they matter most. Phase 1 alone is expected to move the two Critical risks into a Low residual band, and the completion of Phases 1 and 2 is expected to eliminate all Critical and High residual exposure.

The implementation priorities are therefore a direct expression of the risk treatment objectives. Each phase corresponds to a risk-level tier, each control traces to a specific treatment decision and ISO/IEC 27002 mapping, and each expected outcome corresponds to the residual-risk estimate recorded in the treatment plan. By following the roadmap, AL-ITTIHAD converts its analyzed and prioritized risks into a measurable programmed of improvement, ensuring that the controls selected on paper are delivered in practice, in the order that most effectively reduces organizational risk.

F.7 Section Summary

This section has mapped each treated risk to specific ISO/IEC 27002 controls, grouped those controls into eight functional categories, and explained why each was chosen and how it is expected to perform. The mapping confirms that AL-ITTIHAD's treatment plan is fully grounded in recognized good practice and that every significant risk is addressed by at least one defined control with a clear objective. A small number of high-leverage control families — access control, network security, backup management and security awareness — account for most of the risk reduction, reflecting the systemic nature of the underlying weaknesses. The control mapping thus operationalizes the Risk Treatment Plan and provides the assured foundation on which the residual-risk and acceptance analysis in Section G is built.

Section G: Risk Acceptance

G.1 Introduction

Risk acceptance is the formal acknowledgement, by an appropriate authority, that a residual risk may be retained without further treatment. It is the final stage of the ISO/IEC 27005 lifecycle and follows directly from risk treatment: once controls have been selected and their effect estimated, the risk that remains must be explicitly accepted, treated further, or escalated. Acceptance is necessary because residual risk is unavoidable — no realistic set of controls reduces risk to zero, and beyond a certain point the cost of further reduction outweighs the benefit.

Residual risk remains for several reasons: controls reduce but do not eliminate likelihood or impact; some threats, such as zero-day exploits, cannot be fully prevented; and practical, financial and operational constraints limit how far treatment can reasonably go. The role of management in this process is decisive. Because accepting a risk commits the organization to bear its potential consequences, acceptance is a governance decision reserved for those with the authority and accountability to make it — principally the CISO and, for more significant residual exposures, Executive Management. This section assesses the residual risk left after the Section F controls, defines the criteria for acceptance, records the formal acceptance decisions, and sets out how accepted risks will be monitored so that acceptance remains a considered, time-bound decision rather than a permanent disregard of risk.

G.2 Residual Risk Assessment

The table below states, for every risk, the original analyzed level, the treatment applied, and the residual risk level expected once the mapped controls are operating. The residual levels are forward-looking estimates of control effectiveness and do not alter the original analyzed levels recorded in Section C.

Risk ID	Original Risk Level	Treatment Applied	Residual Risk Level	Residual Risk Justification
RS-01	High	Risk Reduction (Mitigation)	Low	Scrubbing and rate-limiting absorb most attack traffic; some availability risk persists during very large or novel attacks.
RS-02	Critical	Risk Reduction (Mitigation)	Low	MFA neutralizes most credential reuse and training cuts click-rates; a small human-factor residual remains.
RS-03	High	Risk Reduction + Transfer	Medium	Immutable backups and EDR assure recovery, but ransomware remains a high-impact threat, leaving a contained residual that transfer partly offsets.
RS-04	High	Risk Reduction (Mitigation)	Low	Input validation and a WAF close the injection path; residual is limited to undiscovered application flaws.
RS-05	Medium	Risk Reduction (Mitigation)	Low	Enterprise authentication removes the enabling weakness; residual interception risk is minimal.
RS-06	Medium	Risk Reduction (Mitigation)	Low	Segmentation and NAC contain lateral spread; residual is limited to a single infected host.
RS-07	Critical	Risk Reduction (Mitigation)	Low	MFA removes the decisive exposure so a stolen password no longer grants access; residual is low.
RS-08	Medium	Risk Reduction (Mitigation)	Medium	Patch discipline and management-plane isolation shrink the exposure window, but zero-day risk cannot be fully eliminated.
RS-09	Low	Risk Acceptance (with monitoring)	Low	Accepted within appetite; monitoring keeps the already-low

Risk ID	Original Risk Level	Treatment Applied	Residual Risk Level	Residual Risk Justification
				insider exposure visible.
RS-10	High	Risk Reduction (Mitigation)	Low	Out-of-band management and lockout/MFA prevent brute-force compromise; residual is low.
RS-11	Medium	Risk Reduction (Mitigation)	Low	Verification behaviours and install restrictions reduce susceptibility; a modest human-factor residual remains.
RS-12	Very Low	Risk Acceptance (with monitoring)	Very Low	Accepted within appetite; basic hardening keeps the minor exposure negligible.

G.3 Risk Acceptance Criteria

The following criteria, derived from the risk-acceptance thresholds defined during Context Establishment (Section A.8), govern whether a residual risk may be accepted, accepted on conditions, or rejected as requiring further treatment.

Acceptance Category	Definition & Criteria	Management Action
Acceptable Risk	Residual risk at Low or Very Low level. The exposure falls within the organization's risk appetite; the likelihood and consequence are sufficiently limited that retention is reasonable.	Accepted by the CISO and retained under routine monitoring.
Conditionally Acceptable Risk	Residual risk at Medium level. May be retained only subject to defined conditions — active monitoring, compensating controls and documented management sign-off — and revisited at the next review.	Accepted on conditions by Executive Management on the CISO's recommendation.
Unacceptable Risk	Residual risk remaining at High or Critical level after treatment. Exceeds appetite and cannot be retained; requires further treatment, transfer or escalation.	Rejected for acceptance; returned for additional treatment or executive escalation.

Applying these criteria to the residual levels in G.2, no risk remains at High or Critical after treatment; ten risks reach a Low or Very Low residual and are Acceptable, while two (RS-03 and RS-08) settle at a Medium residual and are therefore Conditionally Acceptable, retained under the stated conditions.

G.4 Accepted Risk Register

The Accepted Risk Register records the formal acceptance decision for each residual risk, the authority accepting it, the justification, and the frequency at which the decision will be reviewed. It constitutes the organization's documented, auditable record of accepted residual exposure.

Risk ID	Residual Risk Level	Acceptance Decision	Acceptance Justification	Responsible Party	Review Frequency
RS-01	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. Scrubbing and rate-limiting absorb most attack traffic; some availability risk persists during very large or novel attacks.	CISO	Semi-annual
RS-02	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. MFA neutralizes most credential reuse and training cuts click-rates; a small human-factor residual remains.	CISO	Semi-annual
RS-03	Medium	Conditionally Accepted	Residual risk is Medium; retained on condition of active monitoring and the compensating controls mapped in Section F and revisited at each review. Immutable backups and EDR assure recovery, but ransomware remains a high-impact threat, leaving a contained residual that transfer partly offsets.	Executive Management	Quarterly
RS-04	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. Input validation and a WAF close the injection path; residual is limited to undiscovered application flaws.	CISO	Semi-annual
RS-05	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. Enterprise authentication removes the enabling weakness; residual interception risk is minimal.	CISO	Semi-annual
RS-06	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. Segmentation and NAC contain lateral spread; residual is limited to a single infected host.	CISO	Semi-annual
RS-07	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. MFA removes the decisive exposure, so a stolen password no longer grants access; residual is low.	CISO	Semi-annual
RS-08	Medium	Conditionally Accepted	Residual risk is Medium; retained on condition of active monitoring and the compensating controls mapped in Section F and revisited at each review. Patch discipline and management-plane isolation shrink the exposure window, but zero-day risk cannot be fully eliminated.	Executive Management	Quarterly
RS-09	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. Accepted within appetite; monitoring keeps the already-low insider exposure visible.	CISO	Semi-annual
RS-10	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. Out-of-band management and lockout/MFA	CISO	Semi-annual

Risk ID	Residual Risk Level	Acceptance Decision	Acceptance Justification	Responsible Party	Review Frequency
			prevent brute-force compromise; residual is low.		
RS-11	Low	Accepted	Residual risk is within appetite at Low level following treatment; retention is more proportionate than further expenditure. Verification behaviors and install restrictions reduce susceptibility; a modest human-factor residual remains.	CISO	Semi-annual
RS-12	Very Low	Accepted	Residual risk is within appetite at Very Low-level following treatment; retention is more proportionate than further expenditure. Accepted within appetite; basic hardening keeps the minor exposure negligible.	IT Security Manager	Annual

G.5 Cost-Benefit Analysis

The decision to accept certain residual risks rather than pursue further treatment rests on a cost-benefit judgment consistent with the acceptance criteria. For risks already reduced to Low or Very Low residual levels, the marginal cost of additional controls would be high relative to the small further reduction in exposure they would achieve. Spending scarce security budget to drive an already-acceptable risk closer to zero would divert resources from the Critical and High exposures where the same investment yields far greater protection. Acceptance, in these cases, is the economically rational allocation of limited resources.

Financial considerations also shape the treatment of the two conditionally accepted medium risks. For ransomware (RS-03), the residual financial consequence that controls cannot remove is addressed through risk transfer rather than further technical spend, because insurance is a more cost-effective way to absorb a low-frequency, high-cost event than attempting to engineer it out entirely. For the firewall zero-day (RS-08), the cost of eliminating an unknown vulnerability is effectively unbounded, so investment is directed instead at reducing the exposure window and containing impact — a far better return than chasing perfect prevention. In each case the security benefit of additional treatment does not justify its cost, while the residual exposure remains within, or close to, appetite and is kept under active review.

G.6 Business Justification

Beyond cost, the acceptance of residual risk is justified by legitimate business considerations. AL-ITTIHAD must sustain continuous operations across multiple jurisdictions, and some controls that would marginally reduce low-level risks would also introduce operational friction — additional authentication steps, network restrictions or device limitations — disproportionate to the exposure they address. Accepting a Low or Very Low risk avoids degrading service availability and user productivity for negligible security gain, which is itself a sound business outcome.

Operational requirements and service availability further support acceptance. Certain assets, such as the shared printer (RS-12) and the telephony segment (RS-09), must remain readily usable by staff, and over-restricting them would impair the business functions they exist to provide while the underlying risk is already minor. Organizational priorities reinforce the same conclusion: management attention and investment are most valuable when concentrating on the exposures that most threaten the organization's objectives. For all these reasons, complete risk elimination is neither practical nor desirable — the realistic and responsible goal is to reduce risk to an acceptable level and to accept, knowingly and under review, the limited exposure that remains.

G.7 Operational Constraints

Several practical constraints influence how far treatment can proceed and therefore which residual risks must be accepted. Budget limitations cap the total security investment available in any cycle, requiring that funds be prioritized toward the highest risks and that lower risks be retained under monitoring. Legacy systems and devices — including some network and end-user equipment in the inventory — may not support the latest security features, so that compensating controls and monitoring substitute for full technical remediation. Resource constraints, particularly the finite capacity of the IT and security teams, limit how many treatments can be implemented and operated simultaneously, making phased delivery and selective acceptance unavoidable.

Technical limitations also play a part: some threats, such as zero-day exploits, cannot be fully prevented by any available control, and some risks are inherent to the architecture the business requires. Organizational constraints — the need to maintain operations, manage change carefully across jurisdictions, and avoid disrupting users — further bound the pace and extent of treatment. These factors do not weaken the assessment; rather, they make explicit why acceptance is a necessary and legitimate outcome, and they are precisely the conditions that the monitoring plan in G.8 is designed to keep under observation so that accepted risks are revisited if circumstances change.

G.8 Residual Risk Monitoring Plan

Accepted risks are not closed but monitored, so that any change in their likelihood, impact or control effectiveness is detected and the acceptance decision can be revisited. The plan below assigns a monitoring method, a responsible role and a review frequency to each residual risk, drawing the methods directly from the Risk Treatment Plan.

Risk ID	Residual Risk	Monitoring Method	Responsible Party	Review Frequency
RS-01	Low	Real-time traffic dashboards; monthly availability review; periodic DDoS-response drills.	Network Administrator	Semi-annual
RS-02	Low	Quarterly phishing-simulation click-rates; training completion metrics; authentication anomaly alerts.	CISO / IT Security Team	Semi-annual
RS-03	Medium	Scheduled backup-restore tests; EDR alert review; annual incident-response exercises.	IT Infrastructure Team	Quarterly
RS-04	Low	WAF event logs; periodic vulnerability scans and penetration testing.	Database Administrator	Semi-annual
RS-05	Low	Wireless IDS logs; periodic wireless configuration audit.	Network Administrator	Semi-annual
RS-06	Low	EDR and NAC dashboards; periodic segmentation audit.	Network Administrator	Semi-annual
RS-07	Low	VPN authentication logs; anomalous-session alerts; quarterly remote-access reviews.	Security Operations Team	Semi-annual
RS-08	Medium	Patch-compliance reports; threat-intelligence feeds; periodic firewall configuration review.	IT Security Team	Quarterly
RS-09	Low	Periodic call-access log review; periodic access-rights review.	IT Infrastructure Team	Semi-annual
RS-10	Low	Management-access logs; periodic configuration and ACL audit.	Network Administrator	Semi-annual
RS-11	Low	Training metrics; simulated pretext-call exercises.	IT Security Team	Semi-annual
RS-12	Very Low	Periodic printer configuration check.	System Administrator	Annual

G.9 Continuous Review and Improvement

Risk acceptance is valid only at a point in time, because the threat landscape, the asset base and the control environment all evolve. AL-ITTihad therefore embeds the accepted risks within a program of continuous review and improvement. Periodic security reviews re-examine the risk register and the residual levels to confirm that accepted risks remain within appetite and that controls continue to operate as intended. Regular vulnerability assessments identify newly disclosed weaknesses in the asset base, feeding directly into the vulnerability-management control and potentially reopening a previously accepted risk.

Periodic penetration testing validates, from an attacker's perspective, that the controls mapped in Section F are effective in practice and that residual exposures behave as estimated. Security audits provide independent assurance that the ISMS, including its acceptance decisions, is functioning and compliant. Policy reviews keep the governing rules — access, configuration, backup and acceptable use — current with the organization's risk posture, and user-awareness reviews measure and refresh the human-factor defenses on which several treatments depend. Together these activities ensure that monitoring is active rather than passive: they convert risk acceptance from a one-time sign-off into an ongoing, evidence-based discipline that detects drift, prompts re-treatment when necessary, and supports the long-term reduction of organizational risk.

G.10 Final Conclusion

The control mapping and risk-acceptance analysis completes the risk management cycle for this engagement. The ISO/IEC 27002 controls selected in Section F operationalize the treatment plan and are expected, once implemented, to reduce every Critical and High risk to a Low residual level and to hold the Medium risks at or near appetite, materially strengthening AL-ITTIHAD's security posture relative to the perimeter-weighted baseline identified earlier in the report.

The resulting residual-risk posture is acceptable and well understood. After treatment, no risk remains at High or Critical level; ten risks are accepted as Low or Very Low within appetite, and two — ransomware (RS-03) and the firewall zero-day (RS-08) are conditionally accepted at medium level under defined monitoring and compensating controls. Each acceptance has been made by an appropriate authority, justified by cost, business and operational grounds, and recorded in the Accepted Risk Register for audit.

These accepted risks are carried forward as defined monitoring obligations rather than closed items: each has an assigned owner, a monitoring method and a review frequency, and all are embedded in the continuous-review program that will revisit them as conditions change. On this basis, AL-ITTIHAD's cybersecurity readiness can be judged sound and improving — its significant risks are treated by recognized controls, its residual exposure is within appetite and under active management, and the organization possesses a documented, repeatable framework for sustaining and enhancing its security posture across all its jurisdictions.